Computers & Security 173 (2027) 105215

Contents lists available at ScienceDirect

Computers & Security

journal homepage: www.elsevier.com/locate/cose

Vulnerability management: Survey, taxonomy, and challenges

Ehab Alkhateeb *, Saqib Hakak, Arbaaz Dharmavaram, Saeid Bahmanisangesari, Ali Ghorbani

Canadian Institute for Cybersecurity, University of New Brunswick, 15 Dineen Drive, Fredericton, E3B 5A3, New Brunswick, Canada

ARTICLE INFO

Keywords:
Vulnerability management
Cybersecurity
Taxonomy
Threat intelligence
Exploitability
Risk scoring
Network security

ABSTRACT

Vulnerability management plays a crucial role in safeguarding modern digital systems against evolving threats. As software environments grow increasingly complex, traditional approaches have struggled to keep pace with the rapid changes in the threat landscape. Despite the significance of this field, only a limited number of surveys exist, and most focus on outdated methodologies, failing to capture recent advancements. In this article, we present a comprehensive review of recent developments in vulnerability management, emphasizing emerging tools, techniques, and research trends from both academic and industry perspectives. We categorize these approaches based on key dimensions such as data ontologies, prioritization strategies, and integrated frameworks. Additionally, we propose a taxonomy of vulnerability management and briefly discuss the current challenges facing the domain. Our goal is to provide an up-to-date overview of the field and outline promising directions for future research.

Contents

1. Introduction 2
2. Background 3
   2.1. Vulnerability management: definition and lifecycle 3
   2.2. Evolution of vulnerability management 4
   2.3. Vulnerability management for cyberthreats 4
3. Survey on recent advances in VM 4
   3.1. Data source ontologies 4
   3.2. Scoring vulnerabilities 6
      3.2.1. Static severity scoring 6
      3.2.2. Dynamic risk scoring 7
   3.3. Framework 7
4. Vulnerability management taxonomy 9
   4.1. Data collection 9
   4.2. Prioritization 10
   4.3. Mitigation 12
   4.4. Monitoring 12
5. Advances in VM tools 13
   5.1. Comprehensive VM and risk assessment 13
   5.2. Network and endpoint security 14
   5.3. Application security and DevSecOps integration 14
   5.4. Security information and event management (SIEM) and log analysis 14
   5.5. Specialized and open-source tools 14
   5.6. Runtime exploit mitigations and memory safety 15
6. Challenges in vulnerability management 15
   6.1. Limitations in semantic similarity datasets 15
   6.2. Lack of publicly available tools 16

* Corresponding author.
E-mail addresses: ehab.alkhateeb@unb.ca (E. Alkhateeb), saqib.hakak@unb.ca (S. Hakak), arbaaz.dm@unb.ca (A. Dharmavaram), saeid.bahmanisangesari@unb.ca (S. Bahmanisangesari), ghorbani@unb.ca (A. Ghorbani).

https://doi.org/10.1016/j.cose.2026.105215
Received 23 October 2025; Received in revised form 21 July 2026; Accepted 15 October 2026
Available online 27 October 2026
0167-4048/© 2026 Elsevier Ltd. All rights are reserved, including those for text and data mining, AI training, and similar technologies.

6.3. Lack of scoring metric ... 16
6.4. Lack of exploitation and zero-day sources ... 16
6.5. Organizational challenges ... 16
6.6. Remediation tracking and assignment ... 16
6.7. Actionable solutions ... 17
7. Future research directions: toward an integrated VM framework ... 17
7.1. Vision for an all-in-one vulnerability management system ... 17
7.2. Subcomponent spotlight: internet-wide exposure via shodan ... 17
7.3. Enabling technologies: AI, ontologies, and feedback loops ... 17
7.4. Research and development agenda ... 17
8. Future work ... 17
9. Conclusion ... 17
CRediT authorship contribution statement ... 18
Declaration of competing interest ... 18
Acknowledgments ... 18
Data availability ... 18
References ... 18

1. Introduction

In the rapidly evolving landscape of modern computing, the proliferation of connected devices, cloud services, and distributed systems has significantly expanded the digital attack surface. Technological advancements — particularly the rise of the Internet of Things (IoT), edge computing, and artificial intelligence — have redefined the boundaries of traditional IT infrastructures. Although these innovations have brought unprecedented convenience and efficiency, they have also introduced complex security challenges, most notably the management of software and hardware vulnerabilities in diverse and often resource-constrained environments.

Vulnerability management (VM) has become a cornerstone of cybersecurity strategy, with the aim of identifying, assessing, prioritizing and addressing weaknesses before malicious actors can exploit them. However, the surge in malware variants, targeted attacks, and automated exploitation techniques has outpaced traditional reactive defense mechanisms. For example, recent malware campaigns often incorporate obfuscation, polymorphism, and supply chain attack vectors, making vulnerability detection and response increasingly difficult (Alkhateeb et al., 2024b,a; Alkhateeb, 2024). IoT ecosystems, in particular, pose unique risks due to inconsistent patching practices, limited computational resources, and a lack of unified security standards.

Organizations struggle to keep up with the growing number of newly reported software vulnerabilities, often listed in the National Vulnerability Database (NVD) (Hanif et al., 2021). Effective VM now requires more than just accurate detection. Contemporary approaches must also incorporate intelligent prioritization, contextual threat assessment, and automation to ensure timely and effective mitigation. These growing challenges have catalyzed extensive research in multiple domains, including asset discovery, vulnerability scanning, risk-based prioritization, and remediation frameworks. However, the reliability and sustainability of the key infrastructure that supports this ecosystem have recently been subject to scrutiny. In April 2025 (Krebs, 2025), the Common Vulnerabilities and Exposures (CVE) program — central to vulnerability identification and historically funded by the federal government — faced the prospect of funding termination. Although a temporary extension of 11-months of funding was granted, the uncertainty surrounding long-term support has raised concerns among cybersecurity professionals about the resilience of global vulnerability coordination mechanisms (The Verge, 2025). This development underscores the fragility of relying on centralized government-supported systems for global cybersecurity coordination. A disruption to the CVE program or the NVD could lead to delays in vulnerability disclosure, inconsistent data availability, and fragmented risk assessment processes. As a result, there is a growing need for more resilient, decentralized, and community-driven vulnerability intelligence frameworks that can ensure continuity and transparency regardless of institutional or funding changes.

As proposed in this survey, recent advances in VM research are systematically categorized across key dimensions: data sources and ontologies, scoring methodologies, and integrated solutions. We also introduce the VM 360 (VM360) taxonomy, which provides a structured lens for analyzing the literature. This work highlights progress, persistent gaps, and emerging challenges in functional areas, including data modeling, risk prioritization, and remediation frameworks.

Although vulnerability databases (e.g., CVE, NVD, and vendor-specific repositories such as those maintained by Kaspersky and Trend Micro) are widely used as the backbone, they primarily address vulnerability identification and cataloging rather than lifecycle management. In contrast, vulnerability management research builds upon these data sources to support decision-making across identification, prioritization, mitigation, and monitoring. Table 1 summarizes existing survey efforts in this domain and highlights their coverage limitations. Unlike prior surveys, VM360 provides an explicit mapping of existing approaches across all lifecycle stages, enabling a structured comparison of their coverage and identifying gaps in mitigation and monitoring components. This survey bridges the gap by focusing on the latest contributions and highlighting ontology-based, score-based, and hybrid approaches. To demonstrate the practical relevance of the proposed VM360 taxonomy, this survey incorporates several real-world case studies that illustrate how the identified research directions can be operationalized across different organizational environments. For example, in large cloud infrastructures such as AWS or Azure-based deployments, VM360's Data Collection stage can be directly aligned with continuous asset discovery tools (e.g., Amazon Inspector, Azure Defender) that automatically inventory ephemeral workloads and feed normalized vulnerability data into centralized Security Information and Event Management (SIEM) platforms. In enterprise settings, risk-based prioritization can be observed through the operational use of exploit prediction models, such as Exploit Prediction Scoring System (EPSS), or machine-learning–driven prioritization engines deployed by security vendors. These models help reduce remediation backlogs by filtering thousands of detected CVEs down to a small set of vulnerabilities that are both actively exploited and associated with business-critical systems. The Mitigation and Monitoring stages are also reflected in real production workflows. For instance, organizations using automated patch orchestration platforms (e.g., Windows Server Update Services (WSUS), System Center Configuration Manager (SCCM), or Ansible-based pipelines) can rapidly deploy patches across hybrid environments while verifying remediation success through continuous scanning loops. Threat intelligence feeds and SOC alerting further support the Monitoring phase by identifying new exploits or configuration drifts, enabling security teams to reassess and update their VM strategies in real time. Collectively, these examples showcase how VM360

Table 1
Summary of previous surveys on VM. The last row highlights the current survey (This work) for comparative purposes.

Reference	Year	Description	Collection	Prioritization	Mitigation	Monitoring	Tools
Le et al. (2022)	2022	Focus on NLP/ML for SV assessment and prioritization. Highlights challenges and task modeling.	✓	✓	–	–	~
Elder et al. (2024)	2024	Emphasizes exploit prediction techniques. Limited to software; lacks mitigation or lifecycle scope.	–	✓	–	–	–
Liu et al. (2025)	2025	Empirical study on OSS CVEs and GitHub disclosures. Highlights timelines and project impacts.	✓	~	–	–	–
Jiang et al. (2025a)	2025	Reviews prioritization metrics and proposes scoring taxonomy. No broader lifecycle analysis.	–	✓	–	–	–
This work	**2026**	Introduces the VM360 taxonomy, which covers the full VM lifecycle, including tools, CTI, and risk models.	✓	✓	✓	✓	✓

Note: ✓= *fully addressed*, ~ = *partially addressed*, – = *not addressed*.

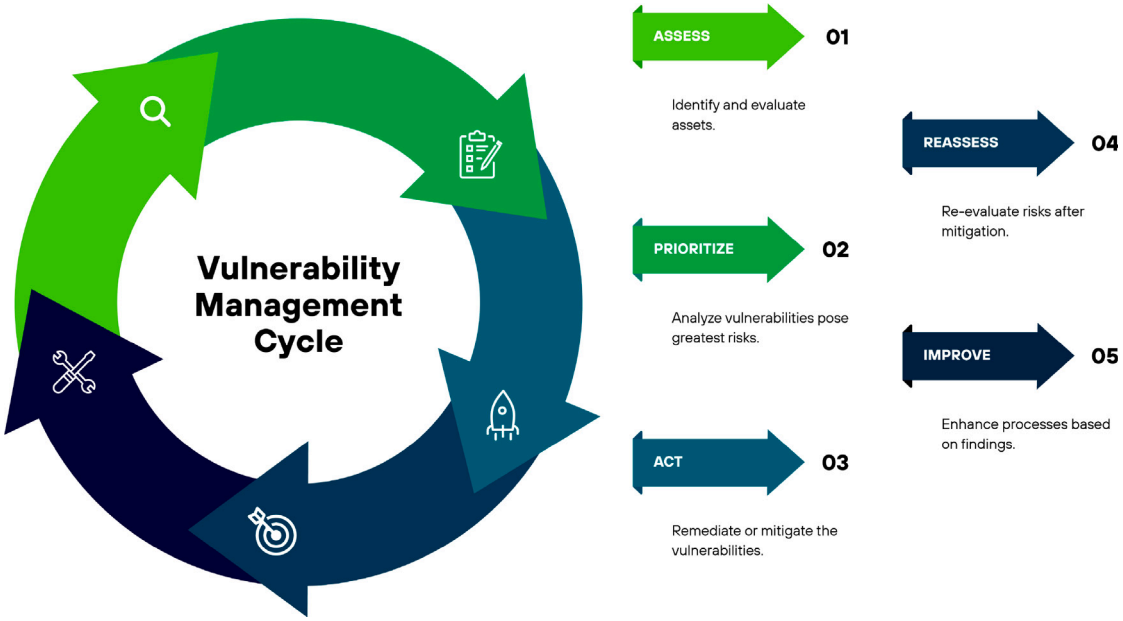


Fig. 1. Vulnerability management cycle.

maps naturally to existing industry workflows and highlight where advanced research — such as ontology-based modeling or adaptive scoring — can significantly enhance operational security outcomes.

The following is the list of contributions in this paper:

- To the best of our knowledge, this is the first comprehensive survey that systematically reviews the most recent and advanced developments in the field of VM, covering literature up to 2025.
- We propose a comprehensive taxonomy for VM comprising four main categories: data collection, prioritization, mitigation, and monitoring. This taxonomy offers a structured framework to understand and optimize the end-to-end VM lifecycle. Each category represents a critical stage, from gathering threat intelligence to executing responses and tracking remediation efforts. By clearly defining these components, our taxonomy provides a foundation for integrating fragmented approaches and moving toward all-in-one solutions that unify detection, risk assessment, and response within a cohesive system.
- We provide a detailed analysis of current challenges in VM, including limitations of existing scoring systems, the lack of semantic interoperability among ontology-based models, the absence of real-time, context-aware frameworks, and the difficulty of integrating mitigation and monitoring components across the VM lifecycle.

The organization of this work is as follows. Section 2 provides background information on VM, including an overview of its key components. Section 3 presents a systematic discussion of the surveyed literature. Section 4 introduces a taxonomy that classifies existing approaches based on key characteristics. Section 5 discusses existing VM tools. Section 6 outlines existing challenges in the VM domain, and Section 7 highlights potential directions for future research. Section 8 discusses potential future work. Finally, Section 9 concludes the article.

2. Background

In this section, we provide an overview of Vulnerability Management (VM), including its definition, lifecycle, and importance for maintaining the security posture of an organization's IT infrastructure.

2.1. Vulnerability management: definition and lifecycle

VM is a proactive and continuous security process focused on the identification, prioritization, mitigation, and reporting of security weaknesses throughout an organization's IT infrastructure (Mell

et al., 2005; Walkowski et al., 2021). By systematically addressing vulnerabilities before they can be exploited, organizations can significantly reduce their attack surface, mitigate the risks posed by zero-day exploits, and avoid the complexities and costs of reactive incident response.

This process is operationalized through a structured lifecycle, often referred to as the VM Lifecycle illustrated in Fig. 1, which encompasses five key stages (Imtiaz, 2022):

- Assess: Identify and evaluate organizational assets for potential vulnerabilities using tools such as network-based scanners or agent-based solutions. This stage ensures comprehensive visibility into the threat landscape.
- Prioritize: Analyze the identified vulnerabilities based on asset criticality, exploitability, and contextual threat intelligence to determine which pose the greatest risk and require immediate attention.
- Act: Implement mitigation or remediation actions. Depending on the context, this may involve installing patches, deploying workarounds, or accepting the risk of low-priority issues.
- Reassess: Validate the effectiveness of the actions implemented and detect residual or new vulnerabilities, ensuring that mitigation measures remain effective and up-to-date.
- Improve: Refine VM strategies based on insights gathered throughout the process. This includes updating tools, policies, and procedures to adapt to evolving threats and enhance overall security resilience.

By integrating these steps into a continuous feedback loop, VM becomes an essential component of an organization's cybersecurity strategy, enabling rapid detection and effective response to emerging threats.

2.2. Evolution of vulnerability management

Vulnerability management (VM) has evolved significantly over the past few decades, driven by the increasing complexity and scale of modern IT infrastructure. In earlier stages, security teams relied on manual processes and expert judgment to identify and remediate system weaknesses. However, with the rapid expansion of networked systems and the growing volume of disclosed vulnerabilities, automated vulnerability scanners such as Nessus and OpenVAS have become essential tools for systematically detecting known security flaws. These technologies have enabled a transition from ad hoc and reactive assessments to structured, continuous, and repeatable vulnerability management processes. As highlighted in recent studies, modern VM practices emphasize not only detection, but also prioritization and remediation, making a shift toward more proactive and risk-driven security strategies (Walkowski et al., 2021; Hanif et al., 2021).

In the 2000s, the integration of vulnerability management with patch management and configuration baselines improved response times and remediation accuracy. More recently, the focus has shifted toward continuous monitoring and real-time analytics, supported by Security Information and Event Management (SIEM) platforms and threat intelligence feeds. Furthermore, machine learning and automation techniques are increasingly being adopted to prioritize vulnerabilities based on exploitability and business impact. This progression reflects the growing need for adaptive and proactive defense mechanisms in increasingly complex IT environments. In summary, vulnerability management has transitioned from reactive and manual practices to dynamic, intelligence-driven processes.

2.3. Vulnerability management for cyberthreats

Vulnerability management (VM) is not a one-time activity but a continuous and iterative process. It constitutes a fundamental pillar of cybersecurity strategy, ensuring that known weaknesses are identified and remediated before adversaries can exploit them. Efficient VM helps maintain a robust defense posture against evolving cyber threats and preserve the stability, confidentiality, and integrity of an organization's IT infrastructure. Modern approaches integrate automated scanning tools, continuous asset discovery, and risk-based prioritization to improve accuracy and efficiency. Furthermore, the adoption of threat intelligence feeds allows security teams to correlate vulnerabilities with active exploit campaigns, improving decision-making and response times. Regular patch management, configuration hardening, and security baseline enforcement are essential elements of this lifecycle. Beyond detection and remediation, the process now emphasizes metrics, reporting, and feedback loops to support compliance with industry standards and regulatory frameworks. Ultimately, a mature VM program enables proactive risk reduction and long-term cybersecurity resilience in dynamic and heterogeneous environments (Tounsi and Rais, 2018).

3. Survey on recent advances in VM

Recent advances in Vulnerability Management (VM) can be categorized into three key areas: Data Source Ontologies, Scoring Vulnerabilities, and Frameworks for VM. Research on Data Source Ontologies has focused on developing standardized structures for organizing and linking data across vulnerability feeds, thereby improving data interoperability and risk assessment. In Vulnerabilities Scoring, advances have enhanced existing systems such as CVSS by incorporating real-world attack vectors, machine learning for dynamic scoring, and business context to generate more accurate, context-aware vulnerability ratings. The development of VM frameworks has introduced more automated, integrated, and continuous processes, improving overall efficiency and alignment with cybersecurity standards. This section reviews the most influential and reputable research conducted in these areas between 2016 and 2025, while Table 2 presents a comprehensive summary of recent works. The section particularly highlights the most prevalent and impactful studies to illustrate key developments and trends in VM.

3.1. Data source ontologies

Data source ontologies in VM help standardize and categorize information from various security databases, threat intelligence feeds, and system logs. They enable better correlation, analysis, and automation of vulnerability detection and mitigation. In this section, we focus on this category. To provide a structured comparison of these approaches, Table 3 summarizes the key data source ontologies discussed in this section.

To improve the accuracy of databases such as the NVD Ahmet Okutan's study Okutan et al. (2023) introduced a novel system for automated curation and characterization of vulnerabilities. This system overcomes traditional manual, time-consuming, and error-prone processes by converting textual vulnerability reports into structured data using natural language processing and machine learning techniques. The evaluation of the system demonstrates notable time savings and high vulnerability characterization accuracy, indicating a considerable improvement in VM. Okutan's contribution is the development and validation of this automated approach, which showcases its potential for real-time data processing and vulnerability characterization in line with the NIST VDO framework (Booth and Turner, 2016).

In the field of cybersecurity, a noteworthy investigation into the integration of ontology and machine learning (ML) techniques is presented in a recent study (Aranovich et al., 2021). This research aims to bolster cybersecurity mechanisms by leveraging an ontology framework applied to structured NVD data. The proposed TRONTO system distinguishes itself by its proficiency in aggregating vulnerability information from social media platforms. To further enhance its capabilities, the system incorporates a BERT classifier. This strategic integration not

Table 2
Timeline of the surveyed works.

Year	Reference	Ontology-based	Score-based
2016	Bojanova et al. (2016)	✓	×
	Booth and Turner (2016)	✓	×
2017	Wu et al. (2017)	✓	×
	Almukaynizi et al. (2017)	×	✓
2018	Tavabi et al. (2018)	×	✓
	Angelini et al. (2018)	✓	×
	Falco et al. (2018)	✓	×
	Farris et al. (2018)	✓	✓
	Garg et al. (2018)	✓	✓
2019	Andrei (2019)	✓	✓
	Alperin et al. (2019)	×	✓
	Chen et al. (2019a)	×	✓
	Chen et al. (2019b)	×	✓
	Dong et al. (2019)	×	✓
2020	Syed (2020)	✓	✓
	Vanamala et al. (2020)	×	✓
	Ani et al. (2020)	✓	✓
	Anjum et al. (2020a)	×	✓
	Anjum et al. (2020b)	×	✓
	Dissanayaka et al. (2020)	✓	✓
	Fang et al. (2020)	×	✓
2021	Walkowski et al. (2021)	×	✓
	Aranovich et al. (2021)	✓	×
	Jacobs et al. (2021)	×	✓
	Guo et al. (2021)	×	✓
	Yosifova et al. (2021)	×	✓
	Pastuszuk et al. (2021)	✓	✓
	Girol et al. (2021)	✓	✓
2022	Ahmadi Mehri et al. (2022)	✓	✓
	Aivatoglou et al. (2022)	×	✓
	Almazrouei and Magalingam (2022)	✓	×
	Colombelli et al. (2022)	×	✓
	Costa et al. (2022)	×	✓
	Costa and Tymburibá (2022a,b)	×	✓
	Croft et al. (2022)	×	✓
	Forain et al. (2022)	×	✓
	Wang et al. (2022)	×	✓
2023	Bojanova and Guerrerio (2023)	✓	×
	Jacobs et al. (2023)	×	✓
	Jagadeesan et al. (2023)	×	✓
	Kühn et al. (2023)	×	✓
	Okutan et al. (2023)	✓	×
	Cheng et al. (2023)	✓	×
2024	Iannone et al. (2024)	×	✓
	Santana et al. (2024)	×	✓
	Angelelli et al. (2024)	✓	✓
	Cheimonidis and Rantos (2024)	×	✓
	Girol et al. (2024)	✓	✓
2025	Jiang et al. (2025b)	×	✓
	Mirtaheri et al. (2025)	×	✓
	Ghosh et al. (2025)	✓	✓

Table 3
Recent works on data ontologies in vulnerability management.

Reference	Approach	Benefits	Weaknesses
Bojanova and Guerrerio (2023)	Uses the Bugs Framework (BF) to label memory-related CWEs and CVEs through formal cause–operation–consequence chains (classification framework, not a full ontology).	Highlights mapping inconsistencies; supports AI/ML analysis with structured input.	Involves manual labeling; a limited dataset is used for evaluation.
Okutan et al. (2023)	NLP, ML, and IT methods for automated vulnerability aggregation using NIST VDO.	Fast classification (up to 95 h faster); high accuracy (F-measure > 0.9); reduces manual effort (47%).	Dependent on training data quality, limited CVSS attribute coverage.
Aranovich et al. (2021)	TRONTO: OWL-based ontology system combining NLP and social media mining.	Enables semantic reasoning; integrates structured and unstructured data (e.g., tweets); uses BERT for severity prediction.	Dependent on unvetted social media content; still requires human analyst input.
Bojanova et al. (2016)	Ontology-driven vulnerability classification by cause, attributes, consequences, and bug sites.	Facilitates tool comparison; supports provenance reasoning; extends beyond CWE.	Requires significant tooling; not comprehensive across all vulnerability classes.
Booth and Turner (2016)	Structured ontology using noun groups and relationships for vulnerability descriptions.	Enables automation and integration with scoring systems; improves vocabulary consistency and interoperability.	Requires continuous updates; lacks serialization/encoding specification.

only enables the system to handle advanced queries but also supports an enriched analytical approach to understanding and addressing cybersecurity vulnerabilities.

The use of the Bugs Framework (BF) (Bojanova et al., 2016) for the systematic labeling of software security vulnerabilities was investigated by Bojanova and Guerrerio (2023). They focused in particular on memory-related Common Weakness Enumerations (CWEs) and their relationships with Common Vulnerabilities and Exposures (CVEs). They examined the labeling scheme currently used by the NVD and identified issues, including overlaps and ambiguity in CWE classifications. The BF formalism was presented in the publication as a more accurate way to describe vulnerabilities, potentially improving AI cybersecurity research and supporting automated labeling. Their early investigation into systematic BF-CWE-CVE mappings and the application of BF to enhance vulnerability labeling are the results of their work.

3.2. Scoring vulnerabilities

Prior research has explored various prioritization methodologies, ranging from static CVSS-based enhancements to dynamic machine learning models. While these studies offer valuable insights into exploit prediction and contextual scoring, they often operate within disparate frameworks. In contrast to these individual prioritization efforts, our work focuses on the underlying taxonomy and ontology required to unify these fragmented approaches. We classify this prior work into two primary categories:

- Static severity scoring – Studies that begin with Common Vulnerability Scoring System (CVSS) or Common Weakness Scoring System (CWSS) vectors and build on what those frameworks lack–such as incorporating deployment environment, business impact, or early-warning heuristics–while retaining the static scoring structure.
- Dynamic or predictive scoring – Techniques that augment static scores with external threat intelligence, organizational context, and exploit data. Examples include the EPSS and its numerous hybrid extensions, which aim to forecast the likelihood or impact of real-world exploitation.

For each category, we first review the foundational frameworks and its core metric groups, then survey key academic extensions in chronological order. This classification of vulnerability scoring approaches underscores how the field has progressed from fixed-parameter models toward adaptive systems that respond to the evolving threat landscape.

3.2.1. Static severity scoring

The Common Vulnerability Scoring System (CVSS) has evolved through four main iterations while retaining its core goal of providing a vendor-neutral, 0–10 severity score. CVSS v1 (2004) (Allodi and Massacci, 2014) introduced the now-familiar Base, Temporal, and Environmental groups but relied on coarse, manually tuned metrics. CVSS v2 (2007) (Allodi and Massacci, 2014) refined exploitability and impact calculations, fostering widespread adoption but still ignored contextual nuance. CVSS v3.0 (2015) (Forum of Incident Response and Security Teams (FIRST), 2015) split "Access Complexity" into Privileges Required and User Interaction, added a Scope metric for cross-boundary impacts, and re-scaled several factors — yet empirical studies showed limited correlation with real-world exploits (Spring et al., 2021, 2018; Howland, 2023). CVSS v3.1 (2019) (Forum of Incident Response and Security Teams (FIRST), 2019) was primarily a clarification-focused update that reinforced the distinction between severity and risk. CVSS v4.0 (2023) (Forum of Incident Response and Security Teams (FIRST), 2023) replaced the Temporal group with a *Threat* group, introduced optional Supplemental metrics (e.g. safety, asset value), and broadened impact definitions beyond the Confidentiality, Integrity and Availability (CIA) triad, aiming for greater flexibility while keeping the canonical Base score unchanged (Balsam et al., 2024).

Stakeholder-Specific Vulnerability Categorization (SSVC) (Cybersecurity and Infrastructure Security Agency (CISA), 2022) extends the CVSS by using a decision-tree-based approach specifically designed to help organizations prioritize responses to vulnerabilities based on their unique contexts and stakeholder perspectives (Spring et al., 2019). Unlike traditional severity-based scoring frameworks such as CVSS, SSVC prioritizes remediation by explicitly accounting for organizational impact, exploitability, and contextual relevance, thereby tailoring VM to each organization's risk profile.

Walkowski et al. (2021) presents an open-source Vulnerability Management Center (VMC) that plugs directly into security scanners (Beale et al., 2004) and inventory databases to automatically calculate CVSS environmental scores for every detected CVE. By enriching each base score with asset-specific context - target-distribution, confidentiality, integrity, and availability requirements, the VMC re-prioritizes remediation effort toward the genuinely high-risk issues that are relevant to the organization. Environmental scoring, as implemented by the VMC, enables more accurate vulnerability prioritization by focusing on contextually critical risks, allowing organizations to optimize remediation efforts and achieve significant efficiency gains in time and resources.

Wang et al. (2022) enhances CVSS 3.1 for Connected and Autonomous Vehicles (CAVs) with $CVSS_{CAV}$, which integrates domain-specific impacts — Safety, Finance, Operation, and Privacy (SFOP) —

into the environmental score using a Bayesian Network. This approach provides a more realistic assessment of CAV vulnerability severity, particularly when data are incomplete. The methodology of environmental scores with critical and sector-specific factors is broadly applicable to other industries seeking more context-aware vulnerability ratings.

Most prior work focuses on predicting CVSS vectors or scores solely from the brief textual descriptions provided in the NVD, Kühn et al. (2023) takes a novel approach by leveraging the publicly referenced web pages linked within NVD entries. These sources, ranging from vendor advisories to technical blogs, are scraped and categorized by relevance, structure, and utility for model training. By combining these additional open-source intelligence (OSINT) texts with NVD descriptions, the authors train deep learning models that outperform previous baselines in predicting CVSS vectors. Their findings highlight the importance of richer and more diverse textual contexts in improving early-stage vulnerability assessment processes. Mirtaheri et al. (2025) presents a comprehensive comparative study evaluating GPT and BERT models for automated vulnerability scoring based on textual descriptions of CVE. Leveraging more than 137,500 entries from the NVD, the authors assess each model family's ability to classify CVSS base metrics, such as Attack Vector and Privileges Required. Although BERT-based models — particularly MediumBERT and SmallBERT — consistently outperform GPT variants in terms of classification accuracy, GPT-4 and fine-tuned GPT-3.5 Turbo show promise in augmenting and rephrasing vulnerability descriptions. In particular, a hybrid GPT-BERT approach, where GPT is used for structured text generation and BERT for classification, yields further improvements, suggesting that combining generative and comprehension capabilities can enhance scoring consistency and effectiveness.

In summary, research on static severity scoring has evolved from coarse metrics of early CVSS versions to multi-dimensional granular assessments of CVSS v4.0 and SSVC. By integrating stakeholder context and domain-specific factors—such as safety impacts in autonomous systems—these frameworks transform a generic 0–10 score into a personalized prioritization tool. Furthermore, the use of ML to predict vectors from OSINT data addresses the critical information gap during early disclosure. Collectively, these advances shift the focus from a universal severity rating to an actionable, organization-specific risk posture.

3.2.2. Dynamic risk scoring

EPSS (2021–2023), developed collaboratively by a global community of cybersecurity practitioners and researchers, offers a significant advancement over the CVSS by explicitly focusing on the likelihood of vulnerability exploitation in the wild (Jacobs et al., 2021, 2023). Unlike CVSS, which primarily captures static vulnerability characteristics and does not account for post-disclosure dynamics, EPSS employs a machine-learning model trained on extensive exploit data from multiple public and proprietary sources, including exploit databases, security advisories, and social media. This approach enables EPSS to dynamically adapt to new information, such as emerging exploits, providing a more accurate, data-driven assessment of exploitation risk. Empirical evaluations show that EPSS improves the identification of vulnerabilities likely exploited compared to CVSS, improving prioritization efficiency; however, both metrics capture complementary aspects of risk and are most effective when used together.

Tavabi et al. (2018) introduces DarkEmbed, a neural language modeling framework designed to predict the exploitability of vulnerabilities using textual data from darkweb and deepweb discussions. Unlike traditional machine learning methods that rely on frequency-based textual representations, DarkEmbed learns low-dimensional embeddings that effectively capture semantic context, thus significantly improving predictive performance. The method uses paragraph vector embeddings to represent discussions, thereby enhancing the model's ability to distinguish genuinely threatening communications from benign ones. Experimental results demonstrate DarkEmbed's superiority over classical text-mining baselines, which produced a notable improvement in F1 score. Furthermore, incorporating additional vulnerability features, such as CVSS scores and exploit availability on ExploitDB, further enhances prediction accuracy, underscoring the potential of context-rich; and embedding-based approaches for proactive vulnerability prioritization.

Iannone et al. (2024) introduces a novel approach to predict the exploitability of newly disclosed vulnerabilities relying exclusively early-stage data, primarily, the initial CVE descriptions and linked online discussions. Acknowledging the inherent delays and limitations of traditional scoring systems such as CVSS, the authors evaluated 72 machine learning models, including classical classifiers and pre-trained large language models (LLMs), across several realistic, time-aware validation scenarios. Their experiments demonstrate that integrating textual data from initial CVE records and online forums, such as Security Focus, notably improves the accuracy of exploitability prediction. Although pretrained LLMs underperformed expectations without domain-specific tuning, the study underscores the potential of early text-based predictive modeling to proactively inform VM immediately after disclosure.

Jiang et al. (2025b) combine probability of exploitation (e.g., EPSS, presence of PoC) with the system-specific context via two automatically generated graphs: *network communication graph* to identify the shortest attack paths to high-criticality assets, capturing how threats can move laterally, and a *system dependency graph* that models functional links between components, enabling analysis of risk propagation across interconnected software and hardware units. Risk is hierarchically aggregated, from vulnerabilities at the component level, to assets, and finally to the entire system, factoring in exploit likelihood (EPSS, PoCs), impact, and graph centrality. Patches are prioritized based on their potential to reduce system-wide risk, enabling efficient high-impact remediation. This system exemplifies the shift toward integrated frameworks that unify static severity, dynamic exploitability, and system topology to enable smarter VM.

Dynamic-risk scoring has progressed from relying on external threat signals to organization-specific risk modeling. Early work first attempted to integrate open chatter (e.g. dark-web discussions, code-repos) to forecast real-world exploits, a concept later expanded and institutionalized by the community-run EPSS, which now delivers daily exploit-probability scores but keeps its underlying data sources proprietary and thus irreproducible. To fill that transparency gap, a follow-up study aims to develop an open-source pipeline to predict early exploitability using only publicly available vulnerability metadata and discussions. The latest work extends the scope from single CVEs to entire systems by using graph models that integrate EPSS-style scores with asset interdependencies. Collectively, these efforts trace a progression from vulnerability-level forecasts to explainable, organization-aware dashboards, providing defenders with earlier, more context-rich guidance on which patches to apply first.

3.3. Framework

Although ontology-based and score-based approaches have individually contributed significantly to VM, recent research has increasingly emphasized the need for integrated solutions. Framework-based models represent a higher level of advancement by combining the structured knowledge representation of ontologies with the dynamic prioritization capabilities of scoring systems. This integration enables more holistic, automated, and context-aware VM workflows that address both semantic clarity and operational urgency. Such frameworks often support real-time decision-making, interoperability between systems, and improved scalability. Framework-based solutions are summarized in Table 4.

Despite these advances in framework-based vulnerability management approaches, current frameworks still face notable limitations. Many rely on static datasets, lack adaptability to emerging threats, or struggle to incorporate heterogeneous data sources. Furthermore, as discussed in our taxonomy in Section 4, many proposed frameworks

Table 4
Recent works on framework-based approaches in vulnerability management.

Reference	Approach	Benefits	Weaknesses
Ghosh et al. (2025)	Ontology-enriched domain-adaptive LLM (CVE-LLM) trained on historical evaluations.	First practical deployment of ontology-assisted LLMs; high accuracy.	Relies on historical data 'templates' that may fail to generalize to novel, non-template-based vulnerabilities.
Angelelli et al. (2024)	Mid-quantile regression (MidQR) with AGR accuracy index.	Introduces the AGR index that is invariant under subsampling. Supports adaptive decision-making.	Statistical complexity may hinder operational adoption; relies on high-quality historical data availability for training, which remains a significant hurdle in the 'secrecy-driven' cybersecurity culture.
Pastuszuk et al. (2021)	Dynamic DCO framework using Shodan and Censys in RDF/OWL.	Enables real-time system analysis and monitoring.	External-only perspective; lacks deep internal asset visibility and struggles with high-fidelity temporal reasoning.
Syed (2020)	Model-driven CVO framework integrating NIST, CVSS, and Twitter data.	Unifies multiple data sources; adds trust-based intelligence.	Siloed approach; relies on predefined reasoning rules and lacks integration with internal enterprise security telemetry.
Andrei (2019)	Semantic annotation framework using DBpedia Spotlight and NVD.	Supports SPARQL queries; enhances NVD with Linked Open Data.	Disjointed from proactive risk-scoring; reliance on static data mapping prevents real-time operational security integration.
Wu et al. (2017)	OWL-based framework with SWRL rules for attack graph generation.	Automates multi-host, multistage attack modeling.	Static modeling; lacks feedback loops from real-world threat actors.

fail to integrate essential aspects of VM, such as mitigation planning and continuous monitoring. The absence of these critical components limits the effectiveness and completeness of such solutions. These shortcomings highlight the need for more comprehensive and intelligent frameworks that are capable of addressing the full lifecycle of VM.

Wu et al. (2017) propose a semantic ontology-based framework integrated with graph theory to enhance security assessments in enterprise networks under multistage, multi-host cyberattacks. Their approach introduces a unified ontology to represent cybersecurity knowledge and facilitates logical reasoning over network configurations. Using OWL and SWRL, the model expresses cause-and-effect relationships between attack steps, while a JESS reasoning engine infers logic-based attack graphs. These graphs serve as stakeholders in shared vocabulary between, allowing for consistent representation and knowledge sharing. The proposed system is evaluated across networks of varying scales and the method demonstrates scalability and precision, with worst-case computational complexity close $O(N^2)$. By combining ontology-driven reasoning with graph-based modeling, this work significantly advances the automation, accuracy, and comprehensibility of network security evaluations.

Andrei (2019) proposes NVD semantic integration model linking with DBpedia to enrich knowledge about software security using Linked Open Data (LOD). The study maps software products and vendors extracted from the NVD's Common Platform Enumeration (CPE) to DBpedia entities via the DBpedia Spotlight API. After manual review and filtering to mitigate generalization errors, the results were incorporated into structured ontologies that model relationships such as produces, isProducedBy, and affects. Although integration enables semantic reasoning and enriched querying, low recall was observed due to DBpedia's limited coverage and ambiguity. Nevertheless, the works contribute reusable RDF models and tools that advance the alignment of structured vulnerability data with semantic web technologies.

Syed (2020) pioneered the development of the Cybersecurity Vulnerability Ontology (CVO), a formal and conceptual model for representing knowledge in VM. Furthermore, they allowed CVO to establish a Cyber Intelligence Alert (CIA) system that issues threat alerts on potential vulnerabilities and their corresponding countermeasures. At the operational level, the CIA system integrates various components such as the Social Media Intelligence Extractor-Tagger (SMIET), the Vulnerability Repository and Mapper, CVO itself, the RDF converter, the Cyber Intelligence Ontology (CIO) and the Engine of Cyber Alert Rules. Lastly, the study elucidated the evaluation methodologies, presented corresponding results, and furnished practical examples to illustrate its application.

Pastuszuk et al. (2021) introduce a Dynamic Cybersecurity Ontology (DCO) and an integrated framework to address the shortcomings of static cybersecurity ontologies in dynamic IT environments. After surveying existing solutions and identifying gaps in real-time data integration, they propose an ontology-driven system that aligns non-semantic, JSON-based infrastructure data from sources such as Shodan and Censys with OWL/RDF-based semantic models. The framework enables administrators to unify dynamic, heterogeneous data within a structured ontology, thereby supporting semantic reasoning and improving cybersecurity awareness. Validated through real-world use cases, including scanning university IP ranges, the work represents a significant step toward integrating live threat intelligence with structured cybersecurity knowledge bases.

Angelelli et al. (2024) introduced a statistical framework for prioritizing vulnerabilities under conditions of incomplete data. By applying mid-quantile regression, the authors bridge the gap between qualitative severity assessments and quantitative risk models without requiring strict parametric assumptions. A key innovation of the framework is a rank-invariance accuracy measure that maintains stable prioritization even when the global vulnerability landscape is only partially observed. Testing both simulated and real-world CVE data, the study demonstrates that integrating intrinsic CVSS scores with extrinsic factors, such as host exposure, significantly improves threat prioritization in operational environments.

Ghosh et al. (2025) advance vulnerability prioritization by automating expert-level assessments through a semantic ontology-driven approach. Their CVE-LLM framework utilizes Large Language Models (LLMs) enriched by cybersecurity ontologies — specifically the SEPSES knowledge graph, CWE, and CAPEC — to evaluate medical device vulnerabilities within a single manufacturer's portfolio. By integrating domain-adaptive pretraining with structured knowledge, the system predicts critical CVSS environmental vectors and generates expert-quality mitigation comments. This methodology significantly reduces the manual burden on cybersecurity experts, transforming raw CVE descriptions into context-aware actionable insights for high-stakes medical deployments.

4. Vulnerability management taxonomy

To structure the complex processes involved in securing modern systems, we introduce Vulnerability Management 360 (VM360), a comprehensive taxonomy that captures the entire VM lifecycle. Unlike existing models that often emphasize individual phases, VM360 integrates four key stages: Data Collection, Prioritization, Mitigation, and Monitoring, each representing critical decision points and operational tasks that contribute to a resilient security posture. The overall structure is illustrated in Fig. 2. In general, VM360 provides a unified lens for analyzing and improving both academic and practical approaches to vulnerability management. The taxonomy contains four main phases:

4.1. Data collection

An effective VM begins with complete data collection. Data sources include vulnerability databases, threat intelligence feeds, security alerts, and automated scanning tools. Publicly available repositories, such as National Vulnerability Database (2024) and the Common CVE database (MITRE, 2024), provide detailed information about known vulnerabilities. In addition, commercial vulnerability scanners and SIEM systems can collect real-time data about network and application vulnerabilities. Integrating external intelligence feeds with internal logs and scans enables organizations to maintain a holistic view of their security landscape.

The data collection phase involves gathering relevant information to identify and assess vulnerabilities. Subcategories include:

- Public databases
  NVD establishes associations between entries in various threat databases. For example, CVE-2022-22965 is linked to weaknesses CWE-502 (Deserialization of Untrusted Data) and CWE-125 (Out-of-bounds Read), and its exploitation impacts specific products identified through CPE entries, such as Apache Struts 2 versions prior to 2.5.30. These associations help vulnerability scanners identify potential risks based on software configurations or packages (Shi et al., 2024).
  In threat modeling, NVD associations map concrete vulnerabilities (e.g., product-specific issues) to abstract weaknesses (e.g., general patterns), aiding higher-level threat analysis. However, creating these associations is time-consuming because it requires manual review and validation by security experts. As a result, the associations provided by the NVD may sometimes be incomplete. Additionally, NVD often faces zero-day vulnerabilities issues, where specific vulnerabilities are discovered and exploited prior to public disclosure, making it challenging to gather detailed mitigation or remediation information. The absence of this crucial information means that the NVD might list a zero-day CVE with limited details, hindering security professionals from quickly applying countermeasures. Furthermore, there may be significant delays in receiving more comprehensive data about these vulnerabilities, especially when vendors or researchers are still investigating or patching the issue. This lack of timely updates can leave organizations exposed to attacks for longer periods, as they cannot act quickly without sufficient data on the risk or mitigation strategies. Consequently, incomplete or delayed CVE information can compromise the effectiveness of the NVD in helping organizations to understand and defend against emerging threats.
- Security scanners:
  Automated vulnerability scanners detect security flaws in applications and networks, such as outdated or unpatched software, and a systematic scanning approach generally improves an organization's security posture (Austin and Williams, 2011). The effectiveness of vulnerability scanning tools is heavily based on the size and freshness of their vulnerability databases. A comprehensive database enables more accurate detection, but since new vulnerabilities are constantly emerging, these tools are only truly effective if their databases are frequently updated. Tools developed by larger companies or organizations are likely to maintain extensive, and regularly updated databases, making them well-suited as all-in-one solutions — especially for small and medium-sized enterprises (SMEs), which typically have limited internal IT support and can only conduct vulnerability assessments periodically. In this context, Araújo et al. (2021) evaluated the performance, accuracy, and resource usage of four free-to-use scanners — OpenVAS, Nessus, Nexpose, and Google's Tsunami. Their tests on diverse operating systems revealed that no tool outperformed the others in all aspects. OpenVAS demonstrated the highest precision, Nexpose offered better accuracy for Linux-based systems, and while Tsunami was resource-efficient, its limited detection plugins made it unsuitable for SMEs in its current state.
  Expanding on the need for practical frameworks to support SMEs, Chalvatzis et al. (2020) developed a reproducible virtual machine-based evaluation model to assess vulnerability scanners in enterprise risk contexts. They compared Nessus, OpenVAS, and the Nmap Scripting Engine (NSE) in terms of scanning performance, CVE coverage, and extensibility through scripting. Their results showed that Nessus had the broadest vulnerability database, OpenVAS offered comparable detection using open-source NASL scripts, and NSE, while fastest and highly customizable via Lua, was limited by its smaller vulnerability library. Their framework contributes to enabling cost-effective, and evidence-based scanner selection and supports integrating vulnerability scan results into broader enterprise risk management processes.
  Despite their utility, scanner-based approaches face practical challenges:

  - Network impact: Scanning, especially across large or sensitive environments, can stress the network bandwidth and system resources. Poorly timed scans may disrupt critical services or degrade production systems.
  - Deployment complexity: Scanners often require credential setup, network segmentation adjustments, and platform-specific configurations. Integrating their results into existing security or risk workflows (e.g., SIEM or GRC systems) adds further operational overhead.
  - Scan depth (authenticated vs. unauthenticated):
    * Authenticated scans allow for deep inspection of system internals, such as registry values, patch levels, or installed software. Although more accurate, they introduce an administrative burden (e.g., managing secure credentials) and potential security risks if they are improperly configured.
    * Unauthenticated scans are easier to deploy but offer only surface-level insights, often missing vulnerabilities that require system-level access to detect.
  - Tool and technology support limitations: Not all scanners support every platform or technology. For instance, some commercial scanners (e.g., Qualys) may lack deep support for non-standard operating systems, containerized environments, or emerging technologies like serverless functions. This creates blind spots, particularly in hybrid or modern cloud-native infrastructures.

  Ultimately, while vulnerability scanners remain a critical part of any security toolkit, organizations must carefully assess their fit-for-purpose across environments and complement them with manual analysis or additional tools where automated coverage falls short.

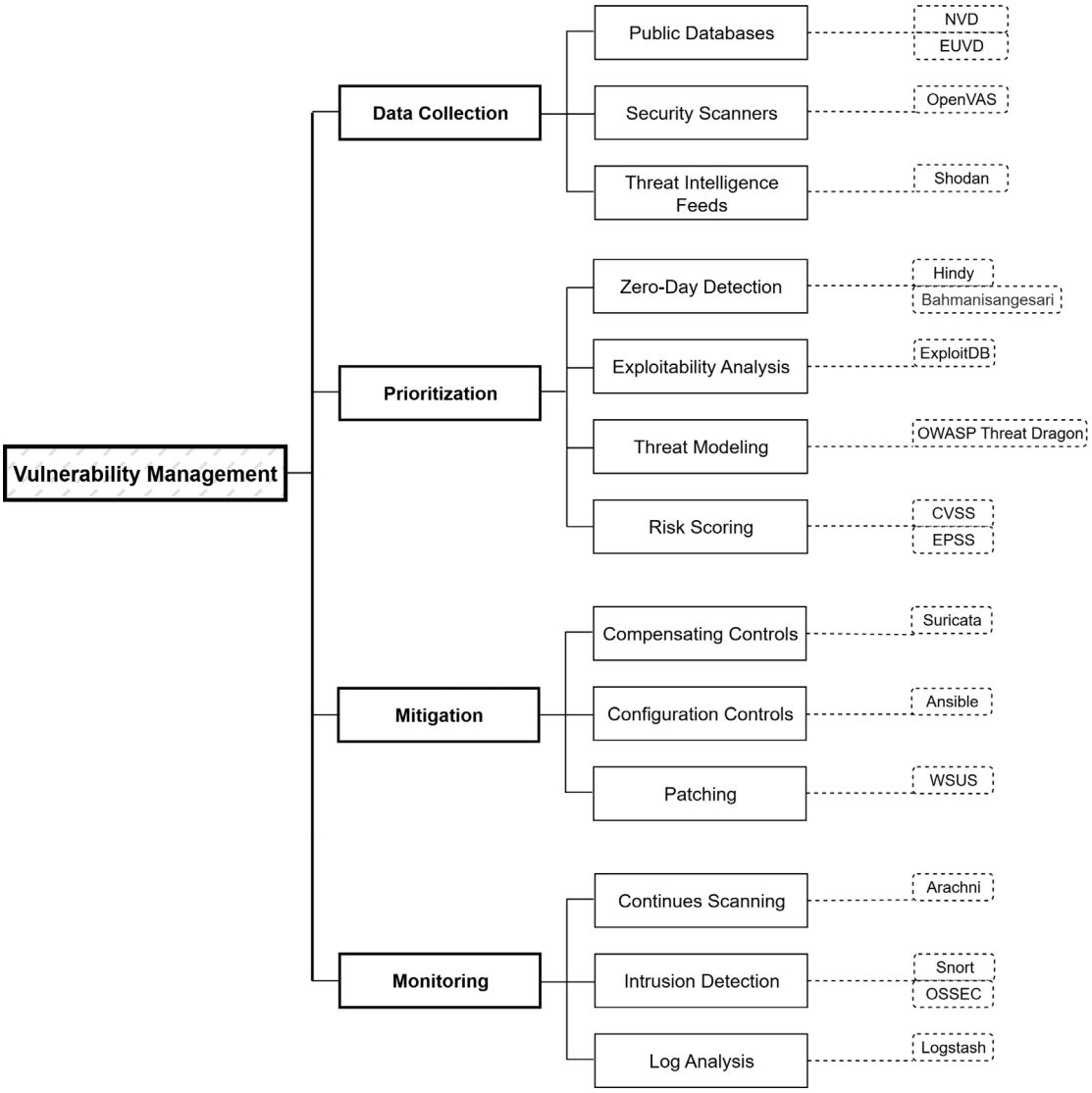


Fig. 2. VM360 taxonomy.

- Threat intelligence feeds and reconnaissance:
  Threat Intelligence Feeds provide curated, real-time data on emerging vulnerabilities, exploits, malware campaigns, and indicators of compromise (IOCs). By integrating these feeds into virtual machine (VM) systems, organizations can prioritize patching based on the relevance and exploitability. Feeds often include CVE references, exploit availability, attacker TTPs (tactics, techniques, and procedures), and threat actor profiles. Leveraging commercial or open-source feeds improves situational awareness and supports risk-based remediation decisions.
  Tools such as Shodan further enrich threat intelligence by scanning and indexing exposed devices to the internet, revealing vulnerable systems, open ports, and unpatched services (Bodenheim et al., 2014). This helps organizations assess their external attack surface and correlate it with known vulnerabilities in real time.
  This form of reconnaissance — also known as internet-wide scann-
  ing — plays a critical role in virtualization by uncovering assets that may be unknown to internal inventory systems, including shadow IT and misconfigured services. Reconnaissance tools collect metadata such as service banners, SSL certificate details, firmware versions, and known CVE tags, allowing security teams to validate the exposure of exploitable systems. When combined with threat intelligence feeds, this reconnaissance supports proactive defense by identifying high-risk systems before adversaries exploit them. Recent literature emphasizes that the value of Cyber Threat Intelligence (CTI) lies not only in the technical depth of feeds but in how intelligence is operationalized organizational practices (Ainslie et al., 2023). This involves integrating structured threat data with proactive reconnaissance tools to support decision-making, risk assessment, and resource prioritization. Reconnaissance outputs — such as services exposed to the internet, fingerprinted systems, and metadata from tools like Shodan — enable organizations to verify whether externally visible systems align with threat indicators from CTI feeds. By combining intelligence collection and exposure mapping, organizations can better tailor their VM strategies to their unique threat landscape and operational context.

4.2. *Prioritization*

Not all vulnerabilities carry the same level of risk, which makes prioritization a critical step in an effective VM. Rather than treating all threats equally, organizations must assess vulnerabilities based on

Table 5
Comparison of risk-based prioritization techniques.

Technique	Examples	Output type	Key benefits
CVSS (Static Scoring)	CVSS v3.1/v4.0, NVD Score	Numerical score (0.0–10.0)	provides a standardized, vendor-neutral baseline for severity assessment.
Zero-Day Detection	CISA KEV, Honeypots, IDS	Real-time alerts or high-risk tags	Enables early response to emerging threats before official patches exist.
Exploitability Analysis	EPSS, ExploitDB, Metasploit	Probability score or exploit flag	Shifts focus to vulnerabilities with high likelihood of exploitation.
Threat Modeling	STRIDE, DFDs, OWASP	Threat-to-asset mapping	Aligns security priorities with specific system design and architectural assets.

their severity, exploitability, and potential operational impact. Within the broader vulnerability taxonomy, prioritization serves as a foundational function, enabling organizations to allocate resources more strategically by ranking vulnerabilities according to risk. This prioritization process typically draws on four complementary components, that can operate in isolation or be combined for greater precision. These are zero-day detection, which identifies previously unknown or unpatched vulnerabilities; exploitation analysis, which examines whether a vulnerability is being actively exploited in the wild; risk scoring systems such as CVSS or enhanced models like EPSS, which provide standardized severity ratings; and threat modeling frameworks (e.g., OWASP), which map vulnerabilities to specific assets, attack vectors, and contextual exposure. Together, these elements form a flexible foundation for improving prioritization and guiding remediation decisions in dynamic threat environments. Table 5 summarizes the main prioritization components, scoring systems, and frameworks used in VM.

- Risk scoring: Vulnerability scoring systems play a pivotal role in quantifying and prioritizing cybersecurity risks. The most widely used model, the Common Vulnerability Scoring System (CVSS), assigns severity scores based on standardized metrics that capture both likelihood and impact. However, recent research efforts have sought to advance beyond static scoring by incorporating temporal dynamics and predictive modeling techniques.
  Kia et al. (2024) propose CyRiPred, a machine learning–based framework designed to predict emerging cyber risks using only CVE records from the NVD. Unlike traditional models that rely heavily on expert judgment, CyRiPred employs natural language processing to map CVE descriptions to higher-level cybersecurity domains through a custom algorithm called WikiTopic, which links terms to corresponding Wikipedia topics. These topics are quantified using the frequency of events and the average CVSS base scores, creating time series data that capture both likelihood and impact over time. The model then calculates risk scores as the product of these dimensions and applies supervised learning — most effectively Random Forests — to forecast future trends. This enables the generation of a dynamic, ranked list of the most pressing cyber threats, updated in real time based on evolving vulnerability data. In contrast to static models such as CVSS or CWE, CyRiPred supports topic-based, environment-agnostic risk forecasting and enhances interpretability by clustering vulnerabilities into semantically coherent groups. This facilitates more actionable information for cybersecurity practitioners, insurers, and policymakers.
  A comprehensive overview of both static and dynamic risk scoring approaches can be found in Section 3.2.
- Threat modeling: Threat modeling is a proactive security approach that helps identify, evaluate, and mitigate potential threats to a system before they are exploited. It involves analyzing the architecture of application, data, flows, and the potential vulnerabilities of the attacker capabilities to uncover and design appropriate defenses. Frameworks like OWASP's threat modeling methodology provide structured processes to map threats to assets and prioritize security measures accordingly. By anticipating how an attacker might exploit a system, threat modeling improves both prevention and risk prioritization.
  The paper by Hajrić et al. (2020) presents a comprehensive review of threat modeling methods, methodologies, and tools, focusing on the STRIDE model and the Microsoft Threat Modeling Tool (MTMT). A case study is conducted on a Web of Things (WoT)-based temperature management system in its design phase. The STRIDE-based software-centric approach identifies 93 threats, with Denial of Service and Elevation of Privilege being the most prevalent. Each threat is evaluated using the DREAD risk model. The results help prioritize mitigation strategies early in the development. The study highlights the iterative nature and practical value of integrating threat modeling from the beginning.
- Exploitability analysis: Exploitability analysis focuses on determining the likelihood that a given vulnerability can or will be exploited in real-world conditions. Consider factors such as the availability of public exploits, ease of exploitation, attacker skill level required, and presence in malware toolkits. This analysis is often supported by platforms such as ExploitDB or MITRE's ATT&CK framework, and plays a vital role in redefining vulnerability prioritization beyond basic severity scores. By assessing the actual activity or potential of exploit, organizations can better allocate resources to the most pressing threats. As in Sun et al. (2021), the authors propose an automated approach to generate informative CVE descriptions from verbose ExploitDB posts using extractive summarization. Their method extracts nine key aspects — such as product, component, impact, and attack vector — via BERT-based NER and QA models. The approach addresses the significant gap between exploit disclosure and CVE publication, improving the quality of CVE documentation and timeliness. Their evaluation confirms the method's high, accuracy and shows that it outperforms existing black-box summarization models in composing structured CVE entries.
- Zero-day detection: Zero-day vulnerabilities — flaws that are unknown to vendors and unpatched at the time of discovery — pose some of the highest risks in cybersecurity due to their unpredictability and exploitation potential. Traditional VM systems are often blind to zero-days until after public disclosure or exploitation occurs. Incorporating proactive zero-day detection mechanisms, such as anomaly-based monitoring, honeypots, or threat intelligence mining, is essential to change from reactive to anticipatory defense strategies. These capabilities improve both the timeliness and relevance of vulnerability prioritization efforts. In Singh et al. (2019), the authors propose a three-layered framework to detect and prioritizing zero-day vulnerabilities using a hybrid detection approach. It combines Snort-based anomaly detection, attack graph generation, and a custom ranking algorithm called AttackRank to evaluate the exploitability of unknown threats. The system filters known attacks, models suspicious activity, and ranks vulnerabilities according to the likelihood of exploitation. When tested in a university network, the framework achieved detection rate of 96% with only 0.3% false positives.
  Similarly, Hindy et al. (2020) presents a three-layer hybrid framework that incorporates Snort, honeypots, and attack graph analysis. The AttackRank algorithm — based on PageRank —

Table 6
Integration of technical, management, and operational controls in the mitigation phase.

Mitigation subcategory	Technical controls	Management controls	Operational controls
Patching	Vendor updates, automated patch tools (e.g., WSUS, SCCM, Ansible).	Patch management policy, risk-based prioritization (CVSS/EPSS).	Scheduled maintenance, patch validation testing, compliance review.
Configuration Changes	Least privilege enforcement, disabling unused services, CIS/STIG baselines.	Configuration management plan, approval workflow, secure baselines.	Monitoring configuration drift, vulnerability re-scans.
Compensating Controls	Firewalls, IPS/IDS, network segmentation, endpoint detection (EDR/XDR).	Risk acceptance documentation, control effectiveness review.	Alert monitoring, control testing, reversion plans.

Table 7
Key subcategories and features of the monitoring phase in VM.

Monitoring subcategory	Focus	Techniques	Challenges
Log Analysis	Systematically review and interpret chronological system event data to detect anomalies, intrusions, and forensic evidence.	Automated parsing, machine learning, clustering, NLP-based analysis.	High-volume log data, inconsistent log formats, multi-source correlation, limited real-time capabilities.
Intrusion Detection	Identify unauthorized or malicious activities by continuously monitoring the behavior of the network and the system .	IDS/IPS systems, flow-based features, decision tree algorithms (e.g. ID3), simplified neural networks, SDN deployment.	Need for realistic datasets, redundancy of features , trade-off between detection accuracy and processing efficiency.
Continuous Scanning	Automated and periodic scanning of systems and applications to detect newly introduced vulnerabilities.	IoT vulnerability scan, authentication protocol evaluation, formal verification tools (Proverif, BAN logic, Scyther, AVISPA).	Resource-constrained environments, scalability, timely detection, balance of security with system performance.

calculates the probability of exploiting by considering the attack vector, complexity, and authentication requirements. This setup also demonstrated a detection rate of 96% with only 0.3% false positives.

Lastly, Bahmanisangesari (2024) introduces a two-phase predictive model that estimates CVSS scores at the time of CVE publication. Integrates DistilBERT for semantic analysis with an ANN for refinement and employs incremental learning for ongoing improvement. The model, tested on over 92,000 NVD CVEs, showed notable gains in accuracy and F1 score, especially when source identifiers were included. Interpretability tools like SHAP and LIME confirm the transparency and reliability of the model.

4.3. Mitigation

Mitigation involves implementing measures to reduce the risk associated with identified vulnerabilities. The goal is to eliminate the vulnerability or minimize its potential impact. This phase focuses on actions taken directly on the vulnerable system or application, such as applying patches or updating configurations. In cases where direct mitigation is not immediately feasible, organizations can implement compensating controls—alternative security measures that reduce risk without removing the underlying vulnerability. Continuous testing and validation are crucial to ensure that mitigations and controls effectively manage risks without introducing new issues.

The mitigation phase can be divided into three primary subcategories: patching, configuration changes, and compensating controls. Each subcategory can be further supported through the application of technical, management, and operational controls. Table 6 summarizes how these control types contribute to each mitigation strategy.

4.4. Monitoring

Monitoring involves continuously monitoring and assessing the security posture of systems to identify emerging vulnerabilities.

Common monitoring activities and their supporting techniques, purposes and challenges are summarized in Table 7. Subcategories include:

- Log Analysis: Log analysis refers to the process of systematically reviewing and interpreting log data generated by computer systems. These logs contain chronological records of system events, including user activity, system operations, errors, and access patterns. In the context of VM, log analysis serves as a foundational tool for: Intrusion detection (e.g., identification of unauthorized access), Anomaly detection (e.g., detecting unusual behavior patterns) and Forensic analysis (e.g., post-incident investigation). Modern systems generate enormous volumes of logs at high speed. Manual review is no longer feasible, especially when attacks manifest in multiple, fragmented events. This has led to the growing use of automation, machine learning (ML), and clustering techniques in log analysis to improve the accuracy and speed of threat-detection.

  Svacina et al. (2020) conducted a systematic review of 34 studies to assess how log analysis supports vulnerability detection and system security monitoring. The paper emphasizes the growing reliance on machine learning, clustering, and natural language processing to automate the processing of high-volume log data. It highlights challenges such as inconsistent log formats, limited real-time capabilities, and the need for better multi-source analysis. The study provides a roadmap for advancing log-based approaches in identifying system weaknesses and operational anomalies
- Intrusion Detection: Intrusion detection systems (IDS) are crucial for identifying unauthorized or malicious activities by continuously monitoring network or system behavior. The effectiveness of these systems is highly dependent on the quality of the data used for their development and evaluation.

  Researchers emphasize the importance of realistic datasets to evaluate IDS performance. As in Sharafaldin et al. (2019), the authors introduce the CICDDoS2019 dataset, which includes 12 modern DDoS attack types and realistic benign traffic generated in a controlled testbed. By extracting 80 flow-based features, they enable the training and benchmarking of machine learning-based IDS. Their results show that decision tree-based algorithms, especially ID3, offer high accuracy and efficient detection performance.

Table 8
Comparison of advanced vulnerability management tools.

Tool	Core functionality	CVSS	0-Day	RT	ML	OS	Primary focus
VMDR (Qualys, Inc., 2025a)	Cloud vulnerability management and orchestration.	Yes	Lim.	Yes	Yes	No	Enterprise VM
Nessus (Tenable, Inc., 2025)	Network and host-based vulnerability scanning.	Yes	Lim.	Yes	Lim.	No	Host/net scans
InsightVM (Rapid7, Inc., 2025a)	Risk-based management and advanced analytics.	Yes	Lim.	Yes	Yes	No	Risk scoring
OpenVAS (Greenbone Networks, 2025)	Community-driven open-source scanner.	Part.	No	No	No	Yes	Comm. scans
MS Defender (Microsoft Corporation, 2025)	Endpoint detection and response (EDR).	Yes	Yes	Yes	Yes	No	Endpoint prot.
Open Source (Snyk Ltd., 2025)	Developer-focused security and code analysis.	Yes	Yes	No	Yes	No	DevSecOps
Shodan (Matherly, 2025)	Internet-facing asset and service discovery.	No	Yes	Yes	Yes	No	Recon/probes
Prisma (Palo Alto Networks, 2025)	Cloud-native security and posture management.	Yes	Yes	Yes	Yes	No	Cloud risk
Cloud Security Platform (Wiz, 2025)	Cloud security visualization and risk assessment.	Yes	Yes	Yes	Yes	No	Cloud posture
Snort (Roesch, 1999)/Suricata (OISF, 2025)	Inline NIDS/IPS and network threat detection.	Yes	No	Yes	No	Yes	Net monitoring
QRadar (IBM Corporation, 2025)	Enterprise SIEM and event correlation.	Yes	Lim.	Yes	Yes	No	Event analytics
Veracode (Veracode, Inc., 2025)	Static and dynamic application security testing.	Yes	Lim.	No	Lim.	No	AppSec/SAST
WSUS (Microsoft, 2015)	Configuration management and patch automation.	No	No	No	No	No	Patching

Note: *RT = Real-time, ML = ML/NLP, OS = Open Source, Lim. = Limited, Part. = Partial.*

Similarly, as in Zhang et al. (2023), other research focuses on improving data quality through feature selection and deep learning. This approach aims to eliminate redundant features, thereby reducing computational load and improving detection accuracy. Such systems often employ simplified neural network structures to balance detection accuracy with processing time and can be deployed in environments like Software-Defined Networking (SDN) for real-time threat detection.

- Continuous Scanning: This refers to the automated and periodic scanning of systems and applications to detect newly introduced vulnerabilities. In the context of IoT security, Saqib and Moon (2023) provide a comprehensive systematic review of the authentication mechanisms in the literature, identifying security challenges that highlight the importance of such proactive detection techniques. Their review maps threats across IoT architecture layers (perception, network, and application), categorizes authentication schemes, and evaluates them through formal security tools such as Proverif, BAN logic, Scyther, and AVISPA. The findings emphasize the need for lightweight, scalable, and secure authentication in resource-constrained IoT environments, where continuous scanning can play a critical role in timely threat identification.

5. Advances in VM tools

VM tools have evolved significantly to address the increasing complexity of cybersecurity threats. This section briefly discusses a range of advanced tools, categorized by their main focus and capabilities, as summarized in Table 8.

Fig. 3 presents a high-level view of the modern vulnerability management ecosystem, highlighting the interplay between heterogeneous security tools across domains such as enterprise VM, endpoint protection, application security, cloud security, SIEM systems, and compensating controls. This ecosystem perspective emphasizes that effective vulnerability management based on the integration of multiple platforms rather than standalone tools.

5.1. Comprehensive VM and risk assessment

Several platforms provide cloud-based VM and risk-based assessment. For example, Qualys VM, Detection, and Response (VMDR) (Qualys, Inc., 2025a) provides comprehensive cloud security through CVSS scoring and machine-learning-based behavioral analysis. In particular, Qualys supports both scanner-based and agent-based architectures, allowing flexible vulnerability detection across various cloud environments.

Scanner-based solutions involve periodic active scans of systems from a central location. This method provides a broad snapshot of visible network assets but can miss devices that are offline or behind firewalls. It may also introduce temporary network load and security exceptions (e.g., firewall rules or credential requirements).

In contrast, agent-based solutions deploy lightweight software agents on endpoints to provide continuous real-time visibility. These agents can function even when devices are off-network or mobile, offering more persistent monitoring. However, they may introduce management overhead (e.g., agent deployment, updates, compatibility).

By supporting both approaches, Qualys allows organizations to tailor their strategy to asset types and network architectures, combining the scalability of scanning with the persistent coverage of agents.

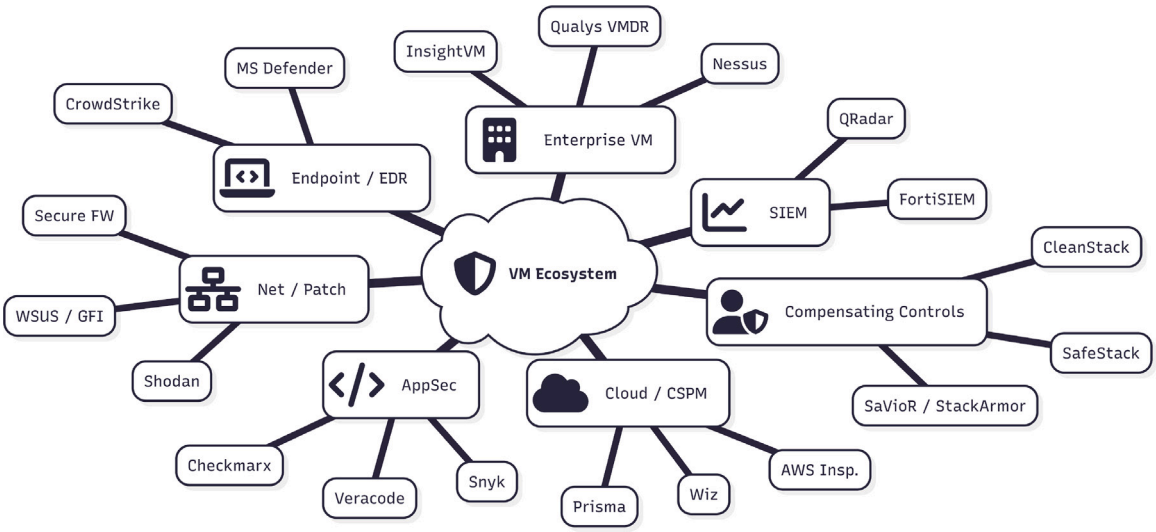


Fig. 3. Classification of the vulnerability management ecosystem.

Similarly, InsightVM (Rapid7, Inc., 2025a) focuses on risk-based management, using CVSS and machine learning to prioritize vulnerabilities through risk scoring. *Tripwire IP360* (Fortra's Tripwire, 2025) also provides risk-based scanning for enterprise management. These tools often integrate real-time capabilities and leverage advanced analytics to help organizations understand and mitigate their most critical risks.

5.2. Network and endpoint security

Network and endpoint protection strategies utilize a spectrum of tools, ranging from traditional vulnerability scanners to advanced Endpoint Detection and Response (EDR) platforms. Tenable Nessus (Tenable, Inc., 2025) and Rapid7 Nexpose (Rapid7, Inc., 2025b) are prominent solutions for host and network scanning, providing automated CVSS scoring and vulnerability assessment. Microsoft Defender for Endpoint (Microsoft Corporation, 2025) and CrowdStrike Falcon (CrowdStrike, Inc., 2025) represent next-generation EDR solutions, offering comprehensive endpoint protection, proactive threat detection, and real-time analysis through the extensive application of machine learning. For network-level monitoring, Snort (Roesch, 1999) and Suricata (OISF, 2025) function as inline Network Intrusion Detection and Prevention Systems (NIDS/IPS), focusing primarily in packet inspection and signature-based detection. Additionally, Cisco Secure Firewall (Cisco Systems, Inc., 2025) integrates firewall functions with IPS capabilities to provide robust perimeter defense.

5.3. Application security and DevSecOps integration

The industry shift toward DevSecOps has necessitated specialized tools for securing applications throughout the development lifecycle. Snyk (Snyk Ltd., 2025) is a development-centric security platform that integrates with DevSecOps workflows, emphasizing code security and proactive threat detection. Static Application Security Testing (SAST) tools, such as Checkmarx (Checkmarx Ltd., 2025) and Veracode (Veracode, Inc., 2025), provide automated source code analysis to identify potential vulnerabilities. For analysis of web applications scanning, Qualys WAS (Qualys, Inc., 2025b), Acunetix (Invicti Security, 2025), Arachni (Laskos, 2014), and the OWASP Zed Attack Proxy (ZAP) (OWASP Foundation, 2025b) are widely used to identify OWASP Top 10 risks. Additionally, Burp Suite (PortSwigger Ltd., 2025) remains the industry standard toolkit for manual web-based penetration testing.

5.4. Security information and event management (SIEM) and log analysis

Integrated security platforms, categorized as SIEM systems, aggregate VM, event correlation, and security analytics into a unified framework. Platforms such as AlienVault OSSIM (AlienVault LLC, 2010) and IBM QRadar (IBM Corporation, 2025) represent enterprise-grade solutions that provide integrated vulnerability scanning and real-time event correlation while leveraging machine learning for behavioral analysis. Similarly, Fortinet FortiSIEM (Fortinet, Inc., 2025) delivers robust SIEM capabilities, emphasizing visibility and security analytics. For fundamental log processing and ingestion, Logstash (Elastic, 2025) serves as a versatile data pipeline engine, often used alongside broader security orchestration tools.

5.5. Specialized and open-source tools

A variety of specialized and open-source tools address specific aspects of VM. OpenVAS (Greenbone Networks, 2025) and OWASP ZAP (OWASP Foundation, 2025b) are notable open-source scanners driven by community efforts. Shodan (Matherly, 2025) specializes in Internet asset discovery and reconnaissance, identifying exposed services and devices around the world. For cloud environments, AWS Inspector (Amazon Web Services, Inc., 2025) provides VM specifically for AWS resources. Patch management tools such as GFI LanGuard (G.F.I. Software, 2025) and WSUS (for Windows environments) focus on automating software updates. Nmap (Lyon, 2009) remains a fundamental open-source tool for network discovery and port scanning. Finally, OWASP Threat Dragon (OWASP Foundation, 2025a) helps with visual threat modeling, helping to develop secure design principles. OSSEC (Lhotsky, 2013) is a host-based IDS focused on file and log monitoring, while Ansible (Lillegard, 2015) is a configuration management tool that can be used for patch automation.

These diverse tools, with their varying functionalities and focuses, collectively contribute to a robust VM ecosystem, enabling organizations to proactively identify, assess, and mitigate security risks.

Cloud-native services such as AWS Inspector automatically discover and scan cloud workloads for software and network vulnerabilities (data collection) and generate risk scores to guide remediation priorities (Amazon Web Services, Inc., 2025). Tools embedded in larger security ecosystems, such as Microsoft Defender for Cloud and endpoint-centric platforms like Microsoft Defender Endpoint and CrowdStrike Falcon, contribute to data collection and contextual prioritization through telemetry and threat detection, while also enabling

Table 9
Comparison of runtime exploit mitigations and memory safety tools.

Mitigation	Primary mechanism	Key advantage	Major limitation
CleanStack	Heuristic-based stack cleaning and integrity monitoring.	High precision in detecting evasion with minimal performance lag.	Effectiveness depends on the accuracy of the heuristic model.
StackArmor	Binary instrumentation and adaptive protection.	Comprehensive coverage for legacy binaries without source code.	Can introduce significant runtime overhead in compute-intensive apps.
SaVioR	Formal verification and static analysis.	Provides mathematical guarantees against specific exploit classes.	High complexity in setup; struggles with dynamic or modular code.
SafeStack	Stack partitioning (Safe vs. Unsafe stacks).	Extremely low overhead (often <1%) for standard buffer overflows.	Limited protection against advanced stack pivoting or data-only attacks.

alerting and integration with response workflows. SIEM and security analytics platforms such as IBM QRadar, Fortinet FortiSIEM, and AlienVault OSSIM primarily ingest events and vulnerability signals from other tools to enable correlation, prioritization, and long-term monitoring.

Open-source scanners such as OpenVAS, OWASP ZAP, Arachni, and Nmap align closely with the data collection phase due to their core scanning and enumeration capabilities. Reconnaissance tools such as Shodan similarly contribute to external asset and service discovery. IDS/HIDS and log processing engines such as Snort, Suricata, OSSEC, and Logstash are aligned with the monitoring phase through signature-based detection and continuous log analysis. Remediation-centric tools such as Ansible, WSUS, and GFI LanGuard are mapped to mitigation given their roles in configuration automation, patch deployment, and system hardening. Developer and application security tools, including Snyk, Checkmarx, Veracode, Qualys WAS, Acunetix, and Burp Suite, support vulnerability and risk discovery with varying degrees of prioritization through integration with CI/CD pipelines and reporting frameworks. Finally, secure design and threat modeling tools such as OWASP Threat Dragon inform early-stage risk analysis and vulnerability identification within software development lifecycles. Together, this mapping reflects how each platform contributes to one or more stages of the continuous VM process, grounded in documented product functionality and industry characterization of their roles.

5.6. Runtime exploit mitigations and memory safety

While traditional VM focuses on identification and administrative remediation, runtime exploit mitigations provide critical compensating control by shielding unpatched vulnerabilities from exploitation during execution. These tools operate at the compiler or binary level to protect the system's stack and memory integrity.

SafeStack (Kuznetzov et al., 2018) offers a high-performance approach by partitioning the stack into "safe" and "unsafe" areas, protecting return addresses from simple buffer overflows with minimal overhead. In contrast, StackArmor (Chen et al., 2015) provides broader protection for legacy binaries through comprehensive instrumentation, though often at the cost of higher runtime latency. SaVioR (Lee et al., 2021) represents a formalist approach, utilizing static analysis and formal verification to mathematically prove the absence of specific vulnerability classes within the code.

Bridging the gap between these approaches, CleanStack (Chong, 2025) usesa dual-stack architecture driven by heuristics. By focusing specifically on "tainted" data objects most susceptible to manipulation, CleanStack identifies and mitigates both control-flow and non-control data attacks. As summarized in Table 9, CleanStack offers a precision-oriented defense that addresses modern evasion techniques while maintaining a significantly lower performance footprint than instrumentation-heavy alternatives such as StackArmor.

The functional mapping of tools to the VM360 phases (Fig. 4) is derived from the documented capabilities of each platform across the vulnerability management lifecycle. Enterprise platforms such as Qualys VMDR span all four phases, providing asset discovery and vulnerability detection (Data Collection), risk-based prioritization using threat intelligence, automated remediation including patch deployment (Mitigation), and continuous monitoring through dashboards and reporting. Similarly, Rapid7 InsightVM offers broad lifecycle coverage, combining continuous scanning, contextual prioritization, and remediation tracking. In contrast, tools such as Tenable Nessus and Nexpose are primarily concentrated in the Data Collection phase, focusing on vulnerability enumeration and severity assessment, while relying on external integrations to support mitigation and monitoring activities. This mapping highlights a clear distinction between comprehensive platforms that support end-to-end VM workflows and specialized tools that focus on individual phases, reinforcing the need for integrated ecosystems in modern vulnerability management.

6. Challenges in vulnerability management

Vulnerability management (VM) is a complex and evolving field that faces several challenges, particularly in the areas of data access, tool availability, and scoring accuracy. The effectiveness of VM relies on having comprehensive and timely data, as well as the right tools to assess, prioritize, and remediate security risks. However, the lack of publicly available resources — such as reliable datasets, exploitation data, and accessible tools — creates significant barriers. These limitations hinder the ability to accurately assess and respond to vulnerabilities, often leading to misaligned risk prioritization and delayed remediation efforts. This section discusses some of the key challenges faced in VM, including limitations in semantic similarity datasets, a lack of publicly available tools, the absence of diverse scoring metrics, and the difficulty in accessing real-world exploitation and zero-day data.

6.1. Limitations in semantic similarity datasets

Various datasets have been released to evaluate the performance of Natural Language Process (NLP) models. Specifically, the Microsoft Research Paraphrase Corpus (MRPC) dataset of the General Language Understanding Evaluation (GLUE) benchmark (Wang et al., 2018) labels sentence paraphrases of each other in English, making it highly valuable for developing models to measure sentence similarity and assess their performance. This data set was used to evaluate the Receiver Operating Characteristic (RoC) to measure the similarity between security descriptions and news articles related to CVE and Common Weakness Enumeration (CWE), as used in this study. However, the MRPC dataset does not focus primarily on texts related to security issues. Thus, constructing an optimal model to assess the similarity between CVE, CWE, and security-related news articles presents challenges. Another issue is the significant length disparity between the security descriptions of CVE, CWE, and news articles. Although the Universal Sentence Encoder (USE) algorithm (Cer et al., 2018) used in this study for similarity measurement is less sensitive to sentence

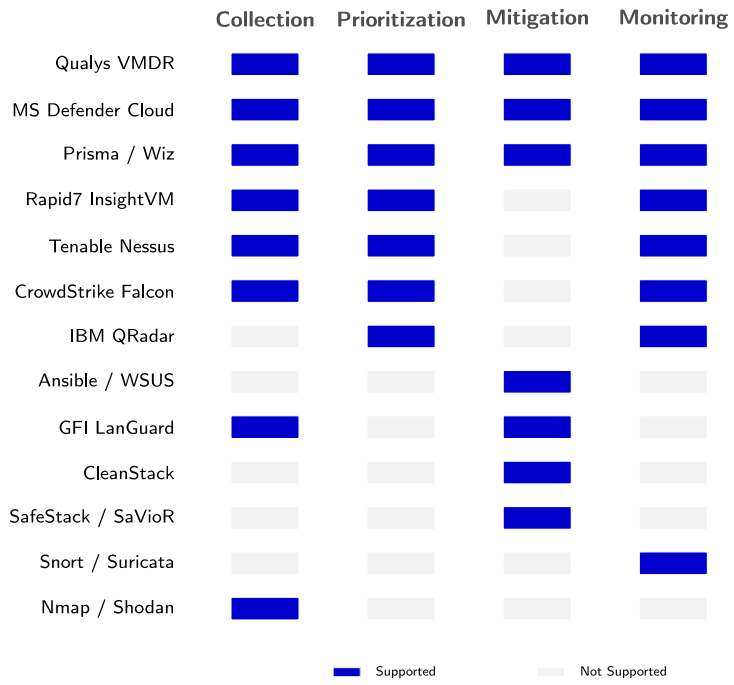


Fig. 4. Capability graph of vulnerability management platforms across the VM360 phases.

length differences during the embedding process, a large discrepancy in sentence lengths can still negatively impact the accuracy of similarity assessments. Future research is required to address these challenges mentioned above.

6.2. Lack of publicly available tools

VM suffers from a lack of publicly available tools, making it difficult for smaller organizations and resource-constrained teams to effectively identify, prioritize, and remediate security risks. Most comprehensive solutions are commercial, often expensive and complex to deploy, making them beyond the reach of many. Although there are some open-source tools, they frequently lack ongoing maintenance, regular updates, user-friendly interfaces, and integration capabilities with modern IT environments. This creates a significant gap in timely threat detection and response, leaving many systems vulnerable to exploitation. The absence of standardized, accessible tools also hampers collaboration and knowledge sharing within the cybersecurity community. Addressing this issue requires coordinated efforts to invest in open, community-driven tool development and support, enabling broader adoption of best practices and more equitable access to effective VM solutions.

6.3. Lack of scoring metric

One major challenge in VM is the limited availability of diverse, context-aware scoring metrics beyond widely used systems such as CVSS and EPSS. These scoring methods have been central to many recent large-scale efforts to improve vulnerability prioritization. CVSS provides severity scores based on technical attributes, while EPSS predicts the likelihood of exploitation using statistical models. However, despite their widespread adoption, both still fall short in capturing real-world risk. They often fail to account for asset criticality, organizational context, business impact, and live threat intelligence, which are crucial for accurate prioritization. As a result, organizations may focus on vulnerabilities that are technically severe but operationally low-risk, while overlooking those that pose immediate threats in their specific environments. This gap highlights the need for more dynamic and adaptive scoring models tailored to the diverse needs of different organizations and infrastructures.

6.4. Lack of exploitation and zero-day sources

The lack of publicly available exploitation and zero-day sources presents a critical gap in the field of VM. Effective VM relies not only on identifying and cataloging known vulnerabilities but also on assessing their real-world risk—particularly whether a vulnerability is actively being exploited. However, the limited visibility into zero-day exploits and actual exploitation data makes it difficult to accurately prioritize vulnerabilities based on threat context. This can lead to misaligned patching strategies, where high-risk but unexploited vulnerabilities receive undue attention, while lower-severity flaws being actively exploited may be overlooked. Without access to credible exploitation sources, especially zero-days, organizations and researchers are forced to make risk assessments based on incomplete threat intelligence, undermining the overall effectiveness of vulnerability prioritization and mitigation strategies.

6.5. Organizational challenges

Organizational challenges are often the most difficult to address in VM. Even with advanced tools and methodologies, the lack of advocacy and support from business leaders can prevent security teams from obtaining the necessary resources to effectively manage vulnerabilities. Competing priorities, limited budgets, and the perception of security as a cost center often reduce the visibility and importance of VM within organizations. Without executive-level buy-in, remediation efforts are regularly delayed or underfunded. Future work should focus on strategies for leadership-level awareness, including clearer communication of the business risks associated with vulnerabilities and the potential financial and reputational damage from security incidents.

6.6. Remediation tracking and assignment

Even when vulnerabilities are identified and prioritized, tracking and assigning remediation tasks remain challenging. Many organizations rely on ad hoc methods such as spreadsheets, emails, or manual ticketing systems, which can be prone to errors, duplication, and oversight. The lack of streamlined integration between vulnerability scanners and ticketing systems exacerbates this issue, making it difficult

to monitor remediation progress across multiple teams and systems. This often results in delays, missed deadlines, and inconsistent accountability for remediation tasks. Research into more automated and integrated remediation tracking systems — linked directly to vulnerability scanners, configuration management, and workflow platforms — could improve visibility, accountability, and overall remediation effectiveness.

6.7. Actionable solutions

Integrate vulnerability scanners with automated ticketing and workflow management systems to streamline the assignment and tracking of remediation tasks. Employ interactive dashboards that provide real-time visibility into remediation progress, highlight overdue tasks, and clearly assign responsibilities to specific teams or personnel. Introduce feedback loops in which information on the effectiveness and timeliness of past remediation efforts is fed back into prioritization and scoring models, helping refine risk assessments and improve future decision-making. Additionally, consider automated reminders and escalation mechanisms to ensure high-priority vulnerabilities are addressed promptly, and enable reporting features to keep leadership informed of progress and potential risks.

7. Future research directions: toward an integrated VM framework

Despite significant advances in vulnerability identification, scoring, and threat intelligence, VM remains largely sil0ed and reactive. Existing solutions often address isolated components — such as scanning, prioritization, or patching — without offering holistic, real-time insight into organizational risk exposure. This fragmentation hampers effective decision-making and limits the ability to proactively manage vulnerabilities in complex and dynamic environments.

In this section, we propose a forward-looking vision for an integrated, adaptive, and intelligence-driven VM framework. This all-in-one system aims to unify the most impactful capabilities — exposure awareness, threat modeling, behavioral analysis, scoring, and automated prioritization — into a cohesive architecture. Such a system would enable organizations to transition from static vulnerability lists to risk-informed, actionable decision-support pipelines that are tightly aligned with real-world threat dynamics.

7.1. Vision for an all-in-one vulnerability management system

Current VM practices are fragmented and often require separate tools for asset discovery, scoring, threat modeling, and prioritization. We propose a future direction centered on developing an *integrated, adaptive, and intelligence-driven* VM framework that unifies multiple components under one architecture.

This all-in-one system would incorporate five core pillars:

1. Vulnerability Intelligence and Scoring: Support for CVE, CVSS, and EPSS scoring, enriched with contextual modifiers based on exposure, business impact, and exploit trends.
2. Real-Time Exposure Awareness: Integration with internet-wide scanners like Shodan and Censys to validate whether vulnerable services are externally exposed.
3. Threat Modeling and Attack Path Mapping: Incorporation of OWASP threat modeling and MITRE ATT&CK mapping to contextualize vulnerabilities in relation to attack vectors.
4. Exploitability and Behavioral Analytics: Use of honeypots, sandbox analysis, and threat intelligence feeds to assess the likelihood of active exploitation.
5. Automated Prioritization and Response: Machine learning-driven prioritization pipelines, capable of self-tuning based on feedback from patch management, SIEMs, or SOAR platforms.

7.2. Subcomponent spotlight: internet-wide exposure via shodan

A central enhancement in this vision is the integration of Shodan for real-time exposure validation. Unlike static scoring models, Shodan enables a global scan of publicly accessible services, allowing security teams to correlate known vulnerabilities with live, exposed systems. This capability supports several operational use cases, including exposure-weighted risk scoring, anomaly detection for potential zero-day activity, attack surface mapping, and alert enrichment within incident response workflows. By incorporating real-world exposure data, this approach transforms vulnerability prioritization from a purely theoretical assessment into an operationally informed process, helping defenders focus remediation efforts on vulnerabilities that pose immediate, tangible risk.

7.3. Enabling technologies: AI, ontologies, and feedback loops

To achieve this integration, we envision using:

- Ontologies for consistent knowledge representation across CVEs, assets, and attack vectors.
- Explainable AI to ensure prioritization decisions are transparent and auditable.
- Feedback loops with patching systems and SOC tools to continuously calibrate prioritization effectiveness.

7.4. Research and development agenda

We propose the following directions to drive development of such an integrated system:

- Standardization of exposure and contextual risk attributes in vulnerability datasets
- Creation of public benchmarks and synthetic datasets for evaluating prioritization models
- Design of open APIs for cross-platform integration of threat intelligence, scanning, and scoring tools
- Collaboration between academia, industry, and standards bodies to align scoring models with operational reality

8. Future work

While this survey provides a structured taxonomy and comparative analysis of recent VM approaches, it also highlights several opportunities for future extension and refinement. One important direction involves integrating large language models (LLMs) into VM pipelines to support automated vulnerability classification, contextual risk assessment, and threat intelligence extraction from unstructured security reports.

Future work could also focus on applying the proposed taxonomy to domain-specific environments, such as telecommunications and 5G infrastructure, where vulnerabilities often affect complex software-defined network components and virtualized network functions. Developing specialized datasets and evaluation frameworks for telecom-related vulnerabilities may improve prioritization strategies for Internet Service Providers (ISPs) and critical infrastructure operators.

Additionally, incorporating real-time threat intelligence feeds and large-scale vulnerability repositories, such as the National Vulnerability Database (NVD), could enable more dynamic and adaptive vulnerability prioritization. These extensions would help bridge the gap between academic research and operational cybersecurity practices.

9. Conclusion

In summary, this article provided a thorough examination of the current landscape of VM, covering its core principles, essential standards, and commonly used tools. A structured literature review was

conducted, which resulted in a taxonomy for categorizing and evaluating methodologies in the field. The proposed VM360 taxonomy emerges from this analysis, organizing vulnerability management into four interconnected phases: data collection, prioritization, mitigation, and monitoring. Despite notable development, key challenges persist—especially in areas such as vulnerability prioritization, automation, and the handling of large-scale vulnerability data. Compared to traditional VM approaches, which are often fragmented and focus on isolated tasks such as scanning, scoring, or patching, VM360 provides a more holistic and lifecycle-oriented view that emphasizes integration across all stages of the vulnerability management process. This unified perspective enables better coordination between detection, risk assessment, remediation, and feedback loops. In addition, aspects such as the incorporation of threat intelligence, contextual risk analysis, and scalable approaches for dynamic environments remain insufficiently addressed. This study explored potential remedies and highlighted promising avenues for future research to bridge these gaps and enhance the efficiency, scalability, and resilience of VM systems. As cyber threats continue to evolve in scope and sophistication, the development of robust, intelligent, and adaptive VM strategies will be critical to protecting today's digital ecosystems.

CRediT authorship contribution statement

Ehab Alkhateeb: Writing – review & editing, Writing – original draft, Methodology, Data curation, Conceptualization. **Saqib Hakak:** Writing – review & editing. **Arbaaz Dharmavaram:** Writing – review & editing. **Saeid Bahmanisangesari:** Writing – review & editing. **Ali Ghorbani:** Writing – review & editing.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

This work was partially supported by the National Cybersecurity Consortium (NCC) under grant number 2024-1519. Additional support was provided by the Canadian Institute for Cybersecurity (CIC).

Data availability

No data was used for the research described in the article.

References

Ahmadi Mehri, V., Arlos, P., Casalicchio, E., 2022. Automated context-aware vulnerability risk management for patch prioritization. Electronics 11 (21), 3580. http://dx.doi.org/10.3390/electronics11213580.

Ainslie, S., Thompson, D., Maynard, S., Ahmad, A., 2023. Cyber-threat intelligence for security decision-making: A review and research agenda for practice. Comput. Secur. 132, 103352. http://dx.doi.org/10.1016/j.cose.2023.103352.

Aivatoglou, G., Anastasiadis, M., Spanos, G., Voulgaridis, A., Votis, K., Tzovaras, D., Angelis, L., 2022. A RAkEL-based methodology to estimate software vulnerability characteristics & score-an application to EU project ECHO. Multimedia Tools Appl. 81 (7), 9459–9479. http://dx.doi.org/10.1007/s11042-021-11073-x.

AlienVault LLC, 2010. Securing Control System Networks: The Security Challenges of Control System Networks. Technical Report, AlienVault Whitepaper, URL: https://cdn-cybersecurity.att.com/docs/AlienVault_Industry_Whitepaper_Control_Systems.pdf.

Alkhateeb, E., 2024. Unmasking Stealthy Threats: Techniques for Identifying and Analyzing Obfuscated Malware (Ph.D. thesis). University of New Brunswick, Fredericton, Canada.

Alkhateeb, E., Ghorbani, A., Habibi Lashkari, A., 2024a. Identifying malware packers through multilayer feature engineering in static analysis. Information 15 (2), 102. http://dx.doi.org/10.3390/info15020102.

Alkhateeb, E., Ghorbani, A., Habibi Lashkari, A., 2024b. A survey on run-time packers and mitigation techniques. Int. J. Inf. Secur. 23 (2), 887–913. http://dx.doi.org/10.1007/s10207-023-00759-y.

Allodi, L., Massacci, F., 2014. Comparing vulnerability severity and exploits using case-control studies. ACM Trans. Inf. Syst. Secur. (TISSEC) 17 (1), 1–20. http://dx.doi.org/10.1145/2630069.

Almazrouei, O., Magalingam, P., 2022. The internet of things network penetration testing model using attack graph analysis. In: 2022 International Symposium on Multidisciplinary Studies and Innovative Technologies. ISMSIT, IEEE, pp. 360–368. http://dx.doi.org/10.1109/ISMSIT56059.2022.9932758.

Almukaynizi, M., Nunes, E., Dharaiya, K., Senguttuvan, M., Shakarian, J., Shakarian, P., 2017. Proactive identification of exploits in the wild through vulnerability mentions online. In: 2017 International Conference on Cyber Conflict. CyCon US, IEEE, pp. 82–88. http://dx.doi.org/10.1109/CYCONUS.2017.8167501.

Alperin, K., Wollaber, A., Ross, D., Trepagnier, P., Leonard, L., 2019. Risk prioritization by leveraging latent vulnerability features in a contested environment. In: Proceedings of the 12th ACM Workshop on Artificial Intelligence and Security. ACM, pp. 49–57. http://dx.doi.org/10.1145/3338501.33573.

Amazon Web Services, Inc., 2025. Amazon inspector: Automated security assessment service. https://aws.amazon.com/inspector/. (Accessed 15 May 2025).

Andrei, B., 2019. Building annotated semantic model of software products towards integration of DBpedia with NVD vulnerability dataset. Int. J. Open Inf. Technol. 7 (7), 35–41.

Angelelli, M., Arima, S., Catalano, C., Ciavolino, E., 2024. A robust statistical framework for cyber-vulnerability prioritisation under partial information in threat intelligence. Expert Syst. Appl. 255, 124572. http://dx.doi.org/10.1016/j.eswa.2024.124572.

Angelini, M., Blasilli, G.b., Catarci, T., Lenti, S., Santucci, G., 2018. Vulnus: Visual vulnerability analysis for network security. IEEE Trans. Vis. Comput. Graphics 25 (1), 183–192. http://dx.doi.org/10.1109/TVCG.2018.2865028.

Ani, U.D., He, H., Tiwari, A., 2020. Vulnerability-based impact criticality estimation for industrial control systems. In: 2020 International Conference on Cyber Security and Protection of Digital Services. Cyber Security, IEEE, pp. 1–8. http://dx.doi.org/10.1109/CyberSecurity49315.2020.9138886.

Anjum, M., Kapur, P., Agarwal, V., Khatri, S.K., 2020a. Evaluation and selection of software vulnerabilities. Int. J. Reliab. Qual. Saf. Eng. 27 (05), 2040014. http://dx.doi.org/10.1142/S0218539320400148.

Anjum, M., Kapur, P., Agarwal, V., Khatri, S.K., 2020b. A framework for prioritizing software vulnerabilities using fuzzy best-worst method. In: 2020 8th International Conference on Reliability, Infocom Technologies and Optimization (Trends and Future Directions). ICRITO, IEEE, pp. 311–316. http://dx.doi.org/10.1109/ICRITO48877.2020.9197854.

Aranovich, R., Wu, M., Yu, D., Katsy, K., Ahmadnia, B., Bishop, M., Filkov, V., Sagae, K., 2021. Beyond NVD: Cybersecurity meets the semantic web. In: New Security Paradigms Workshop. pp. 59–69. http://dx.doi.org/10.1145/3498891.3501259.

Araújo, R., Pinto, A., Pinto, P., 2021. A performance assessment of free-to-use vulnerability scanners-revisited. In: IFIP International Conference on ICT Systems Security and Privacy Protection. Springer, pp. 53–65. http://dx.doi.org/10.1007/978-3-030-78120-0_4.

Austin, A., Williams, L., 2011. One technique is not enough: A comparison of vulnerability discovery techniques. In: 2011 International Symposium on Empirical Software Engineering and Measurement. IEEE, pp. 97–106. http://dx.doi.org/10.1109/ESEM.2011.18.

Bahmanisangesari, S., 2024. A Novel Transformer-Based Multi-Step Approach for Predicting Common Vulnerability Severity Score (Master's thesis). University of New Brunswick, Fredericton, Canada.

Balsam, A., Nowak, M., Walkowski, M., Oko, J., Sujecki, S., 2024. Comprehensive comparison between versions CVSS v2.0, CVSS v3.x and CVSS v4.0 as vulnerability severity measures. In: 2024 24th International Conference on Transparent Optical Networks. ICTON, IEEE, pp. 1–4. http://dx.doi.org/10.1109/ICTON62926.2024.10647452.

Beale, J., Meer, H., van der Walt, C., Deraison, R., 2004. Nessus Network Auditing: Jay Beale Open Source Security Series. Elsevier.

Bodenheim, R., Butts, J., Dunlap, S., Mullins, B., 2014. Evaluation of the ability of the shodan search engine to identify internet-facing industrial control devices. Int. J. Crit. Infrastruct. Prot. 7 (2), 114–123. http://dx.doi.org/10.1016/j.ijcip.2014.03.001.

Bojanova, I., Black, P.E., Yesha, Y., Wu, Y., 2016. The bugs framework (BF): A structured approach to express bugs. In: 2016 IEEE International Conference on Software Quality, Reliability and Security. QRS, IEEE, pp. 175–182. http://dx.doi.org/10.1109/MITP.2023.3314368.

Bojanova, I., Guerrerio, J.J., 2023. Labeling software security vulnerabilities. IT Prof. 25 (5), 64–70. http://dx.doi.org/10.1109/MITP.2023.3323089.

Booth, H., Turner, C., 2016. Vulnerability Description Ontology (Vdo): A Framework for Characterizing Vulnerabilities. Technical Report, National Institute of Standards and Technology.

Cer, D., Yang, Y., Kong, S.y., Hua, N., Limtiaco, N., John, R.S., Constant, N., Guajardo-Cespedes, M., Yuan, S., Tar, C., et al., 2018. Universal sentence encoder. http://dx.doi.org/10.48550/arXiv.1803.11175, arXiv preprint arXiv:1803.11175.

Chalvatzis, I., Karras, D., Papademetriou, R., 2020. Reproducible modelling and simulating security vulnerability scanners evaluation framework towards risk management assessment of small and medium enterprises business networks. Indian J. Sci. Technol. 13 (37), 3910–3943. http://dx.doi.org/10.17485/IJST/v13i37.868.

Checkmarx Ltd., 2025. Checkmarx: Static application security testing (SAST). https://checkmarx.com/. (Accessed 15 May 2025).

Cheimonidis, P., Rantos, K., 2024. Dynamic vulnerability severity calculator for industrial control systems. Int. J. Inf. Secur. 23 (4), 2655–2676. http://dx.doi.org/10.1007/s10207-024-00858-4.

Chen, H., Liu, J., Liu, R., Park, N., Subrahmanian, V., 2019a. VASE: A twitter-based vulnerability analysis and score engine. In: 2019 IEEE International Conference on Data Mining. ICDM, IEEE, pp. 976–981. http://dx.doi.org/10.1109/ICDM.2019.00110.

Chen, H., Liu, R., Park, N., Subrahmanian, V., 2019b. Using twitter to predict when vulnerabilities will be exploited. In: Proceedings of the 25th ACM SIGKDD International Conference on Knowledge Discovery & Data Mining. ACM, pp. 3143–3152. http://dx.doi.org/10.1145/3292500.3330742.

Chen, X., Slowinska, A., Andriesse, D., Bos, H., Giuffrida, C., 2015. Stackarmor: Comprehensive protection from stack-based memory error vulnerabilities for binaries. In: NDSS.

Cheng, J., Tan, X., Wang, H., Wang, J., Jiang, X., Jin, Z., 2023. Network vulnerability assessment based on knowledge graph. In: 2023 9th International Conference on Big Data Computing and Communications. BigCom, IEEE, pp. 48–55. http://dx.doi.org/10.1109/BIGCOM61073.2023.00015.

Chong, L., 2025. CleanStack: A new dual-stack for defending against stack-based memory corruption attacks. arXiv preprint arXiv:2503.16950.

Cisco Systems, Inc., 2025. Cisco secure firewall. https://www.cisco.com/c/en/us/products/security/firewalls/index.html. (Accessed 15 May 2025).

Colombelli, F., Matter, V.K., Grisci, B.I., Lima, L., Heinen, K., Borges, M., Rigo, S.J., Barbosa, J.L.V., Righi, R.D.R., Da Costa, C.A., et al., 2022. Multi-objective prioritization for data center vulnerability remediation. In: 2022 IEEE Congress on Evolutionary Computation. CEC, IEEE, pp. 01–08. http://dx.doi.org/10.1109/CEC55065.2022.9870289.

Costa, J.C., Roxo, T., Sequeiros, J.B., Proenca, H., Inacio, P.R., 2022. Predicting CVSS metric via description interpretation. IEEE Access 10, 59125–59134. http://dx.doi.org/10.1109/ACCESS.2022.3179692.

Costa, T.F., Tymburibá, M., 2022a. Challenges on prioritizing software patching. In: 2022 15th International Conference on Security of Information and Networks. SIN, IEEE, pp. 1–8. http://dx.doi.org/10.1109/SIN56466.2022.9970537.

Costa, T.F., Tymburibá, M., 2022b. Exploitability assessment with genetically tuned interconnected neural networks. In: Brazilian Conference on Intelligent Systems. Springer, pp. 596–610. http://dx.doi.org/10.1007/978-3-031-21686-2_41.

Croft, R., Babar, M.A., Li, L., 2022. An investigation into inconsistency of software vulnerability severity across data sources. In: 2022 IEEE International Conference on Software Analysis, Evolution and Reengineering. SANER, IEEE, pp. 338–348. http://dx.doi.org/10.48550/arXiv.2112.10356.

CrowdStrike, Inc., 2025. CrowdStrike falcon: Endpoint protection platform. https://www.crowdstrike.com/products/endpoint-security/. (Accessed 15 May 2025).

Cybersecurity and Infrastructure Security Agency (CISA), 2022. Stakeholder-Specific Vulnerability Categorization (SSVC) Guide. Technical Report, U.S. Department of Homeland Security, URL: https://www.cisa.gov/sites/default/files/publications/cisa-ssvc-guide%20508c.pdf.

Dissanayaka, A.M., Mengel, S., Gittner, L., Khan, H., 2020. Vulnerability prioritization, root cause analysis, and mitigation of secure data analytic framework implemented with mongodb on singularity linux containers. In: Proceedings of the 2020 4th International Conference on Compute and Data Analysis. ACM, pp. 58–66. http://dx.doi.org/10.1145/3388142.3388168.

Dong, Y., Guo, W., Chen, Y., Xing, X., Zhang, Y., Wang, G., 2019. Towards the detection of inconsistencies in public security vulnerability reports. In: 28th USENIX Security Symposium. USENIX Security 19, USENIX Association, pp. 869–885.

Elastic, 2025. Logstash. https://www.elastic.co/logstash. (Accessed 15 May 2025).

Elder, S., Rahman, M.R., Fringer, G., Kapoor, K., Williams, L., 2024. A survey on software vulnerability exploitability assessment. ACM Comput. Surv. 56 (8), 1–41. http://dx.doi.org/10.1145/3648610.

Falco, G., Caldera, C., Shrobe, H., 2018. IIoT cybersecurity risk modeling for SCADA systems. IEEE Internet Things J. 5 (6), 4486–4495. http://dx.doi.org/10.1109/JIOT.2018.2822840.

Fang, Y., Liu, Y., Huang, C., Liu, L., 2020. FastEmbed: Predicting vulnerability exploitation possibility based on ensemble machine learning algorithm. PLoS One 15 (2), e0228439. http://dx.doi.org/10.1371/journal.pone.0228439.

Farris, K.A., Shah, A., Cybenko, G., Ganesan, R., Jajodia, S., 2018. Vulcon: A system for vulnerability prioritization, mitigation, and management. ACM Trans. Priv. Secur. (TOPS) 21 (4), 1–28. http://dx.doi.org/10.1145/3196884.

Forain, I., Albuquerque, R.d., de Sousa Júnior, R.T., 2022. REVS: A vulnerability ranking tool for enterprise security. In: ICEIS (2). pp. 126–133. http://dx.doi.org/10.5220/0011068600003179.

Fortinet, Inc., 2025. FortiSIEM: Security information and event management. https://www.fortinet.com/products/siem/fortisiem. (Accessed 15 May 2025).

Fortra's Tripwire, 2025. Tripwire IP360: Vulnerability management. https://www.tripwire.com/products/tripwire-ip360. (Accessed 15 May 2025).

Forum of Incident Response and Security Teams (FIRST), 2015. CVSS v3.0: Specification Document Version 1.9. Technical Report, FIRST.org, URL: https://www.first.org/cvss/v3-0/cvss-v30-specification_v1.9.pdf.

Forum of Incident Response and Security Teams (FIRST), 2019. CVSS v3.1: Specification Document Version 1.0. Technical Report, FIRST.org, URL: https://www.first.org/cvss/v3-1/cvss-v31-specification_r1.pdf.

Forum of Incident Response and Security Teams (FIRST), 2023. CVSS v4.0: Specification Document. Technical Report, FIRST.org, URL: https://www.first.org/cvss/v4-0/cvss-v40-specification.pdf.

Garg, U., Sikka, G., Awasthi, L.K., 2018. Empirical analysis of attack graphs for mitigating critical paths and vulnerabilities. Comput. Secur. 77, 349–359. http://dx.doi.org/10.1016/j.cose.2018.04.006.

G.F.I. Software, 2025. GFI LanGuard: Network security scanner. https://www.gfi.com/products-and-solutions/network-security-solutions/gfi-languard. (Accessed 15 May 2025).

Ghosh, R., von Stockhausen, H.-M., Schmitt, M., Vasile, G.M., Karn, S.K., Farri, O., 2025. CVE-LLM: Ontology-assisted automatic vulnerability evaluation using large language models. In: Proceedings of the AAAI Conference on Artificial Intelligence, vol. 39, no. 28, pp. 28757–28765. http://dx.doi.org/10.1609/aaai.v39i28.35139.

Girol, G., Farinier, B., Bardin, S., 2021. Not all bugs are created equal, but robust reachability can tell the difference. In: International Conference on Computer Aided Verification. Springer, pp. 669–693. http://dx.doi.org/10.1007/978-3-030-81685-8_32.

Girol, G., Lacombe, G., Bardin, S., 2024. Quantitative robustness for vulnerability assessment. Proc. ACM Program. Lang. 8 (PLDI), 741–765. http://dx.doi.org/10.5281/zenodo.10953315.

Greenbone Networks, 2025. OpenVAS - open vulnerability assessment scanner. https://www.openvas.org/. (Accessed 15 May 2025).

Guo, H., Xing, Z., Chen, S., Li, X., Bai, Y., Zhang, H., 2021. Key aspects augmentation of vulnerability description based on multiple security databases. In: 2021 IEEE 45th Annual Computers, Software, and Applications Conference. COMPSAC, IEEE, pp. 1020–1025. http://dx.doi.org/10.1109/COMPSAC51774.2021.00138.

Hajrić, A., Smaka, T., Baraković, S., Husić, J.B., 2020. Methods, methodologies, and tools for threat modeling with case study. Telfor J. 12 (1), 56–61. http://dx.doi.org/10.5937/telfor2001056H.

Hanif, H., Nasir, M.H.N.M., Ab Razak, M.F., Firdaus, A., Anuar, N.B., 2021. The rise of software vulnerability: Taxonomy of software vulnerabilities detection and machine learning approaches. J. Netw. Comput. Appl. 179, 103009.

Hindy, H., Atkinson, R., Tachtatzis, C., Colin, J.-N., Bayne, E., Bellekens, X., 2020. Utilising deep learning techniques for effective zero-day attack detection. Electronics 9 (10), 1684. http://dx.doi.org/10.3390/electronics9101684.

Howland, H., 2023. CVSS: Ubiquitous and broken. Digit. Threat.: Res. Pr. 4 (1), 1–12. http://dx.doi.org/10.1145/3491263.

Iannone, E., Sellitto, G., Iaccarino, E., Ferrucci, F., De Lucia, A., Palomba, P., 2024. Early and realistic exploitability prediction of just-disclosed software vulnerabilities: How reliable can it be? ACM Trans. Softw. Eng. Methodol. 33 (6), 1–41. http://dx.doi.org/10.1145/3654443.

IBM Corporation, 2025. IBM qradar SIEM. https://www.ibm.com/products/qradar-siem. (Accessed 15 May 2025).

Imtiaz, K., 2022. Vulnerability management lifecycle. URL: https://www.crowdstrike.com/en-us/cybersecurity-101/exposure-management/vulnerability-management-lifecycle/. (Accessed 06 May 2025).

Invicti Security, 2025. Acunetix: Web application security scanner. https://www.acunetix.com/. (Accessed 15 May 2025).

Jacobs, J., Romanosky, S., Edwards, B., Adjerid, I., Roytman, M., 2021. Exploit prediction scoring system (epss). Digit. Threat.: Res. Pr. 2 (3), 1–17. http://dx.doi.org/10.1145/3433944.

Jacobs, J., Romanosky, S., Suciu, O., Edwards, B., Sarabi, A., 2023. Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights. In: 2023 IEEE European Symposium on Security and Privacy Workshops. EuroS&PW, IEEE, pp. 194–206. http://dx.doi.org/10.1109/EuroSPW59978.2023.00027.

Jagadeesan, M., Saravanan, T., Selvaraj, P., Mounika, V., Ramya, D., Kumar, K.V., 2023. Neural network-based software vulnerability classification to enhance accuracy. In: 2023 International Conference on Computer Communication and Informatics. ICCCI, IEEE, pp. 1–5. http://dx.doi.org/10.1109/ICCCI56745.2023.10128467.

Jiang, Y., Oo, N., Meng, Q., Lim, H.W., Sikdar, B., 2025a. A survey on vulnerability prioritization: Taxonomy, metrics, and research challenges. http://dx.doi.org/10.48550/arXiv.2502.11070, arXiv preprint arXiv:2502.11070.

Jiang, Y., Oo, N., Meng, Q., Lim, H.W., Sikdar, B., 2025b. VulRG: Multi-level explainable vulnerability patch ranking for complex systems using graphs. http://dx.doi.org/10.48550/arXiv.2502.11143, arXiv preprint arXiv:2502.11143.

Kia, A.N., Murphy, F., Sheehan, B., Shannon, D., 2024. A cyber risk prediction model using common vulnerabilities and exposures. Expert Syst. Appl. 237, 121599. http://dx.doi.org/10.1016/j.eswa.2023.121599.

Krebs, B., 2025. Funding expires for key cyber vulnerability database. URL: https://krebsonsecurity.com/2025/04/funding-expires-for-key-cyber-vulnerability-database/. (Accessed 14 August 2025).

Kühn, P., Relke, D.N., Reuter, C., 2023. Common vulnerability scoring system prediction based on open source intelligence information sources. Comput. Secur. 131, 103286. http://dx.doi.org/10.1016/j.cose.2023.103286.

Kuznetzov, V., Szekeres, L., Payer, M., Candea, G., Sekar, R., Song, D., 2018. Code-pointer integrity. The Continuing Arms Race: Code-Reuse Attacks and Defenses. pp. 81–116. http://dx.doi.org/10.1145/3129743.312974.

Laskos, T., 2014. Arachni: Web application security scanner framework. https://github.com/Arachni/arachni. (Accessed 15 May 2025).

Le, T.H., Chen, H., Babar, M.A., 2022. A survey on data-driven software vulnerability assessment and prioritization. ACM Comput. Surv. 55 (5), 1–39. http://dx.doi.org/10.1145/3529757.

Lee, S., Kang, H., Jang, J., Kang, B.B., 2021. Savior: Thwarting stack-based memory safety violations by randomizing stack layout. IEEE Trans. Dependable Secur. Comput. 19 (4), 2559–2575.

Lhotsky, B., 2013. Instant OSSEC Host-Based Intrusion Detection System. Packt Publishing.

Lillegard, L., 2015. Ansible: Up and Running. O'Reilly Media.

Liu, S., Zhou, J., Hu, X., Cogo, F.R., Xia, X., Yang, X., 2025. An empirical study on vulnerability disclosure management of open source software systems. ACM Trans. Softw. Eng. Methodol. http://dx.doi.org/10.1145/3716822.

Lyon, G.F., 2009. Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning. Insecure.Com LLC.

Matherly, J., 2025. Shodan: The search engine for internet-connected devices. https://www.shodan.io/. (Accessed 15 May 2025).

Mell, P., Bergeron, T., Henning, D., et al., 2005. Creating a patch and vulnerability management program. NIST Spec. Publ. 800, 40.

Microsoft, 2015. Windows server update services (WSUS). https://learn.microsoft.com/en-us/windows-server/administration/windows-server-update-services/get-started/windows-server-update-services-wsus. (Accessed 15 May 2025).

Microsoft Corporation, 2025. Microsoft defender for endpoint. https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/. (Accessed 15 May 2025).

Mirtaheri, S.L., Pugliese, A., Movahed, N., Shahbazian, R., 2025. A comparative analysis on using GPT and BERT for automated vulnerability scoring. Intell. Syst. Appl. 26, http://dx.doi.org/10.1016/j.iswa.2025.200515.

MITRE, 2024. Common vulnerabilities and exposures (CVE). URL: https://cve.mitre.org. (Accessed 28 December 2024).

National Vulnerability Database, 2024. National vulnerability database (NVD). https://nvd.nist.gov/general. (Accessed 28 December 2024).

OISF, 2025. Suricata: Open source IDS/IPS/NSM engine. https://suricata.io/. (Accessed 15 May 2025).

Okutan, A., Mell, P., Mirakhorli, M., Khokhlov, I., Santos, J.C., Gonzalez, D., Simmons, S., 2023. Empirical validation of automated vulnerability curation and characterization. IEEE Trans. Softw. Eng. http://dx.doi.org/10.1109/TSE.2023.3250479.

OWASP Foundation, 2025a. OWASP threat dragon. https://owasp.org/www-project-threat-dragon/. (Accessed 15 May 2025).

OWASP Foundation, 2025b. OWASP zed attack proxy (ZAP). https://www.zaproxy.org/. (Accessed 15 May 2025).

Palo Alto Networks, 2025. Prisma cloud: Comprehensive cloud security. URL: https://www.paloaltonetworks.com/prisma/cloud. (Accessed 09 October 2025).

Pastuszuk, J., Burek, P., Księżopolski, B., 2021. Cybersecurity ontology for dynamic analysis of IT systems. Procedia Comput. Sci. 192, 1011–1020. http://dx.doi.org/10.1016/j.procs.2021.08.104.

PortSwigger Ltd., 2025. Burp suite: Web vulnerability scanner. https://portswigger.net/burp. (Accessed 15 May 2025).

Qualys, Inc., 2025a. Qualys VMDR: Vulnerability management, detection, and response. https://www.qualys.com/apps/vulnerability-management-detection-response/. (Accessed 15 May 2025).

Qualys, Inc., 2025b. Qualys web application scanning (WAS). https://www.qualys.com/apps/web-application-scanning/. (Accessed 15 May 2025).

Rapid7, Inc., 2025a. InsightVM: Vulnerability management. https://www.rapid7.com/products/insightvm/. (Accessed 15 May 2025).

Rapid7, Inc., 2025b. Nexpose: Vulnerability management solution. https://www.rapid7.com/products/nexpose/. (Accessed 15 May 2025).

Roesch, M., 1999. Snort: Lightweight intrusion detection for networks. In: Proceedings of the 13th USENIX Conference on System Administration. LISA, USENIX Association, pp. 229–238.

Santana, M., Cogo, V.V., de Sá, A.O., 2024. SecScore: Enhancing the CVSS threat metric group with empirical evidences. http://dx.doi.org/10.48550/arXiv.2405.08539, arXiv preprint arXiv:2405.08539.

Saqib, M., Moon, A.H., 2023. A systematic security assessment and review of internet of things in the context of authentication. Comput. Secur. 125, 103053. http://dx.doi.org/10.1016/j.cose.2022.103053.

Sharafaldin, I., Lashkari, A.H., Hakak, S., Ghorbani, A.A., 2019. Developing realistic distributed denial of service (ddos) attack dataset and taxonomy. In: 2019 International Carnahan Conference on Security Technology. ICCST, IEEE, pp. 1–8. http://dx.doi.org/10.1109/CCST.2019.8888419.

Shi, Z., Matyunin, N., Graffi, K., Starobinski, D., 2024. Uncovering cwe-cve-cpe relations with threat knowledge graphs. ACM Trans. Priv. Secur. 27 (1), 1–26. http://dx.doi.org/10.1145/3641819.

Singh, U.K., Joshi, C., Kanellopoulos, D., 2019. A framework for zero-day vulnerabilities detection and prioritization. J. Inf. Secur. Appl. 46, 164–172. http://dx.doi.org/10.1016/j.jisa.2019.03.011.

Snyk Ltd., 2025. Snyk: Developer-first security. https://snyk.io/. (Accessed 15 May 2025).

Spring, J.M., Hatleback, E., Householder, A.D., Manion, A., Shick, D., 2019. Prioritizing Vulnerability Response: A Stakeholder-Specific Vulnerability Categorization. Software Engineering Institute, Carnegie Mellon University, Pittsburgh, PA, White Paper.

Spring, J., Hatleback, E., Householder, A., Manion, A., Shick, D., 2021. Time to change the CVSS? IEEE Secur. Priv. 19 (2), 74–78. http://dx.doi.org/10.1109/MSEC.2020.3044475.

Spring, J., Hatleback, E., Manion, A., Shick, D., 2018. Towards Improving CVSS. Tech. Rep., Software Engineering Institute, Carnegie Mellon University, Pittsburgh, PA.

Sun, J., Xing, Z., Guo, H., Ye, D., Li, X., Xu, X., Zhu, L., 2021. Generating informative cve description from exploitdb posts by extractive summarization. http://dx.doi.org/10.48550/arXiv.2101.01431, arXiv preprint arXiv:2101.01431.

Svacina, J., Raffety, J., Woodahl, C., Stone, B., Cerny, T., Bures, M., Shin, D., Frajtak, K., Tisnovsky, P., 2020. On vulnerability and security log analysis: A systematic literature review on recent trends. In: Proceedings of the International Conference on Research in Adaptive and Convergent Systems. pp. 175–180. http://dx.doi.org/10.1145/3400286.3418261.

Syed, R., 2020. Cybersecurity vulnerability management: A conceptual ontology and cyber intelligence alert system. Inf. Manag. 57 (6), 103334. http://dx.doi.org/10.1016/j.im.2020.103334.

Tavabi, N., Goyal, P., Almukaynizi, M., Shakarian, P., Lerman, K., 2018. Darkembed: Exploit prediction with neural language models. In: Proceedings of the AAAI Conference on Artificial Intelligence, vol. 32, no. 1, pp. 7849–7854. http://dx.doi.org/10.1609/aaai.v32i1.11428.

Tenable, Inc., 2025. Nessus vulnerability scanner. https://www.tenable.com/products/nessus. (Accessed 15 May 2025).

The Verge, 2025. Funding for the world's most critical bug database was about to expire. URL: https://www.theverge.com/news/649314/cve-mitre-funding-vulnerabilities-exposures-funding. (Accessed 21 March 2026),

Tounsi, W., Rais, H., 2018. A survey on technical threat intelligence in the age of sophisticated cyber attacks. Comput. Secur. 72, 212–233. http://dx.doi.org/10.1016/j.cose.2017.09.001.

Vanamala, M., Yuan, X., Roy, K., 2020. Topic modeling and classification of common vulnerabilities and exposures database. In: 2020 International Conference on Artificial Intelligence, Big Data, Computing and Data Communication Systems. IcABCD, IEEE, pp. 1–5. http://dx.doi.org/10.1109/icABCD49160.2020.9183814.

Veracode, Inc., 2025. Veracode: Application security testing. https://www.veracode.com/. (Accessed 15 May 2025).

Walkowski, M., Oko, J., Sujecki, S., 2021. Vulnerability management models using a common vulnerability scoring system. Appl. Sci. 11 (18), 8735. http://dx.doi.org/10.3390/app11188735.

Wang, A., Singh, A., Michael, J., Hill, F., Levy, O., Bowman, S.R., 2018. GLUE: A multi-task benchmark and analysis platform for natural language understanding. http://dx.doi.org/10.48550/arXiv.1804.07461, arXiv preprint arXiv:1804.07461.

Wang, Y., Yu, B., Yu, H., Xiao, L., Ji, H., Zhao, Y., 2022. Automotive cybersecurity vulnerability assessment using the common vulnerability scoring system and Bayesian network model. IEEE Syst. J. 17 (2), 2880–2891. http://dx.doi.org/10.1109/JSYST.2022.3230097.

Wiz, 2025. Wiz: Agentless cloud vulnerability management. URL: https://www.wiz.io/solutions/vulnerability-management. (Accessed 09 October 2025).

Wu, S., Zhang, Y., Cao, W., 2017. Network security assessment using a semantic reasoning and graph based approach. Comput. Electr. Eng. 64, 96–109. http://dx.doi.org/10.1016/j.compeleceng.2017.02.001.

Yosifova, V., Tasheva, A., Trifonov, R., 2021. Predicting vulnerability type in common vulnerabilities and exposures (CVE) database with machine learning classifiers. In: 2021 12th National Conference with International Participation. ELECTRONICA, IEEE, pp. 1–6. http://dx.doi.org/10.1109/ELECTRONICA52725.2021.9513723.

Zhang, L., Liu, K., Xie, X., Bai, W., Wu, B., Dong, P., 2023. A data-driven network intrusion detection system using feature selection and deep learning. J. Inf. Secur. Appl. 78, 103606. http://dx.doi.org/10.1016/j.jisa.2023.103606.



Ehab Alkhateeb completed his Ph.D. in Computer Science at the University of New Brunswick, Canada, in 2024. He also holds an M.Sc. in Computer Science from Al-Zaytoonah University of Jordan (2015) and a B.Sc. in Computer Science from Zarqa University (2012). With more than nine years of industrial and academic experience, Dr. Alkhateeb is currently a Postdoctoral Fellow at the Canadian Institute for Cybersecurity (CIC). He has held key roles focusing on IT infrastructure security in the UAE, Jordan, and Canada. His research interests include Malware Analysis, Cryptography, Machine Learning, Artificial Intelligence, Network Security, and Cyberwarfare.



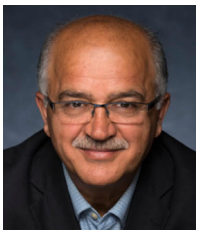
Saqib Hakak is an Associate Professor at the Canadian Institute for Cybersecurity (CIC) within the Faculty of Computer Science at the University of New Brunswick (UNB). With over five years of industrial and academic experience, he has received several gold and silver awards in international innovation competitions. He also serves as a technical committee member and reviewer for numerous reputable conferences and journals. His research interests include risk management, AI-based fake news detection, security and privacy in the IoE, applications of federated learning in IoT, and blockchain technology.



Arbaaz Dharmavaram received his M.Sc. in Computer Science from the University of New Brunswick, Canada, in 2025, and his B.E. in Information Science and Engineering from PES University, Bangalore, India, in 2019. He has first-authored two peer-reviewed publications and holds three U.S. patents filed during his tenure at Target Corporation, spanning safety compliance, product mismatch detection, and image segmentation. He has held engineering roles at Target Corporation, the Vector Institute, the Canadian Institute for Cybersecurity, and Agentiiv. His research and professional interests include Natural Language Processing, Computer Vision, and Full-Stack AI development, with a focus on agentic systems, retrieval-augmented generation, and production-grade ML deployment.



Saeid Bahmanisangesari received his M.Sc. in Computer Science from the University of New Brunswick, Canada, in 2024. He also holds a B.Sc. in Computer Science from Ferdowsi University of Mashhad (2021). Saeid is currently a Cybersecurity Software Developer at the Canadian Institute for Cybersecurity (CIC), where his work focuses on secure software engineering, network security, vulnerability management, and the integration of machine learning and artificial intelligence in cybersecurity.



Ali Ghorbani has held a variety of positions in academia for the past 37 years and is currently a Professor of Computer Science, Tier 1 Canada Research Chair in Cybersecurity, and the Director of the Canadian Institute for Cybersecurity, which he established in 2016. He served as the Dean of the Faculty of Computer Science at the University of New Brunswick from 2008 to 2017 and spent over 27 years of his 37-year academic career there. He is the founding director of the Laboratory for Intelligence and Adaptive Systems Research. His current research interests include Cybersecurity, Web Intelligence, and Critical Infrastructure Protection. He is the co-founder of the Privacy, Security, Trust (PST) Network in Canada and its international annual conference. He is also the co-inventor of three awarded patents and has published over 260 peer-reviewed articles during his career. Dr. Ghorbani has supervised over 170 research associates, postdoctoral fellows, graduate, and undergraduate students. His book, Intrusion Detection and Prevention Systems: Concepts and Techniques, was published by Springer in October 2010. He served as the co-Editor-in-Chief of Computational Intelligence from 2007 to 2017. He co-founded two startups: Sentrant Security in 2013 and EyesOver Technologies in 2015. Dr. Ghorbani was twice one of three finalists for the Special Recognition Award at the 2013 and 2016 New Brunswick KIRA Awards. He is the recipient of the 2017 Startup Canada Senior Entrepreneur Award.